

# SOC Incident Response Playbook

Detection Engineering & Incident Analysis Framework

Prepared for:  
**Green Circle**

**Van Helsing Team Members:**

Mohammed Waleed Mohammed Khalaf

Omar Ahmad Ismail Karajeh

Neam Anwar Mohammed Alhadithi

Areej Usama Mouayad Al-dobagh

Ayat Haitham Khalaf Al-Hamimat

Supervising: Eng. Tareq Obeidat

February 26, 2026

## Contents

|           |                                                               |           |
|-----------|---------------------------------------------------------------|-----------|
| <b>1</b>  | <b>Windows Brute Force (Windows)</b>                          | <b>3</b>  |
| <b>2</b>  | <b>Unauthorized Scheduled Task (Windows)</b>                  | <b>6</b>  |
| <b>3</b>  | <b>Registry Persistence (Windows)</b>                         | <b>9</b>  |
| <b>4</b>  | <b>Privilege Escalation (Windows)</b>                         | <b>12</b> |
| <b>5</b>  | <b>Successful RDP Access (Windows)</b>                        | <b>15</b> |
| <b>6</b>  | <b>Security Event Log Cleared (AD)</b>                        | <b>18</b> |
| <b>7</b>  | <b>Windows Service Creation (AD)</b>                          | <b>21</b> |
| <b>8</b>  | <b>AD Database Extraction - Domain Compromise (AD)</b>        | <b>25</b> |
| <b>9</b>  | <b>Remote Command Execution (AD)</b>                          | <b>28</b> |
| <b>10</b> | <b>SMB Share Enumeration (AD)</b>                             | <b>31</b> |
| <b>11</b> | <b>Successful Root Elevation (Kali)</b>                       | <b>34</b> |
| <b>12</b> | <b>Local Brute Force Detection (Kali)</b>                     | <b>37</b> |
| <b>13</b> | <b>Crontab Modification Detected (Kali)</b>                   | <b>40</b> |
| <b>14</b> | <b>Critical File Modification (Kali)</b>                      | <b>43</b> |
| <b>15</b> | <b>Remote SSH Access (Kali)</b>                               | <b>46</b> |
| <b>16</b> | <b>Firewall Defense Evasion Attempt (Kali)</b>                | <b>49</b> |
| <b>17</b> | <b>SUID Privilege Escalation Discovery (Kali)</b>             | <b>52</b> |
| <b>18</b> | <b>Symbolic Link Hijacking (Kali)</b>                         | <b>55</b> |
| <b>19</b> | <b>Unauthorized Network Promiscuous Mode (Kali)</b>           | <b>58</b> |
| <b>20</b> | <b>Hostname Spoofing/Change Detected (Kali)</b>               | <b>61</b> |
| <b>21</b> | <b>SQL Injection Attempt (Web)</b>                            | <b>64</b> |
| 21.1      | Attacker Vision . . . . .                                     | 65        |
| <b>22</b> | <b>File Inclusion &amp; Directory Traversal Attempt (Web)</b> | <b>68</b> |
| 22.1      | Attacker Vision . . . . .                                     | 69        |
| <b>23</b> | <b>High-Frequency Directory Brute Force Detected (Web)</b>    | <b>72</b> |
| 23.1      | Attacker Vision . . . . .                                     | 73        |
| <b>24</b> | <b>Unauthorized XSS Payload Injection Detected (Web)</b>      | <b>76</b> |
| 24.1      | Attacker Vision . . . . .                                     | 77        |

---

|                                                                        |           |
|------------------------------------------------------------------------|-----------|
| <b>25 High-Velocity DoS Attack Detected via Header Signature (Web)</b> | <b>80</b> |
| 25.1 Alert Settings & Dashboard . . . . .                              | 81        |
| 25.2 Dashboard View . . . . .                                          | 81        |
| 25.3 Attacker Vision . . . . .                                         | 81        |

## Windows Brute Force (Windows)

### Scenario

The monitoring system (SIEM/Local Logs) detected a high volume of failed authentication attempts on a Windows 10 VM. The source of the attack is identified as a Windows 11 machine on the same local network. The attack targets local user accounts via RDP or SMB, attempting to guess passwords in a workgroup environment (No Domain/AD).

### Incident Classification

| Category          | Details                                               |
|-------------------|-------------------------------------------------------|
| Incident Type     | Unauthorized Access - Brute Force (P2P)               |
| Severity          | Medium                                                |
| Priority          | High                                                  |
| Detection Sources | Windows Security Logs (Event ID 4625), SIEM           |
| Timestamp         | 16:49:32                                              |
| Source IP         | 192.168.100.13                                        |
| Affected Hosts    | DESKTOP-GU4Q100                                       |
| MITRE ATT&CK      | T1110.001 (Brute Force: Password Guessing)            |
| Tags              | Windows 10, Workgroup, VM-Security, Local Accounts    |
| Recommendation    | Block Source IP via Firewall & Enforce Lockout Policy |

### Alert Rule & Logic

Logic: Detects more than 10 failed login attempts (Event 4625) within a 5-minute window.

```
index=* source="WinEventLog:Security" (EventCode=4625 OR EventCode=4624)
| eval status=if(EventCode=4625, "Failure", "Success")
| stats
  count(eval(status="Failure")) as failure_count,
  count(eval(status="Success")) as success_count,
  values(TargetUserName) as attempted_users,
  earliest(_time) as first_attempt,
  latest(_time) as last_attempt
  by Source_Network_Address
| where failure_count > 5
| eval attack_type = if(success_count > 0, "Potential Breach (Success after Failure)", "Ongoing Brute Force")
| eval duration_sec = last_attempt - first_attempt
| convert ctime(first_attempt) ctime(last_attempt)
| sort - failure_count
```

## Alert Settings & Dashboard

The screenshot shows the 'Edit Alert' configuration window for an alert named 'Brute Force'. The alert description is: 'Detects potential Windows Brute Force attacks by monitoring Event Codes 4625 (Logon Failure) and 4624 (Successful Logon). The alert triggers when a single source IP'. The alert type is set to 'Scheduled' (with 'Real-time' as an option). It is configured to 'Run on Cron Schedule' with a 'Time Range' of 'All time'. The 'Cron Expression' is set to '\*/\* \* \* \* \*' with an example 'e.g. 00 18 \* \* \* (every day at 6PM)' and a 'Learn More' link. The alert 'Expires' after '24' 'hour(s)'. Under 'Trigger Conditions', the alert is triggered when the 'Number of Results' 'is greater than' '0'. The trigger is set to 'Once' (with 'For each result' as an option). The 'Throttle' checkbox is unchecked. Under 'Trigger Actions', there is a '+ Add Actions' button. The 'When triggered' dropdown is set to 'Add to Triggered Alerts', and the 'Severity' is set to 'High'. There is a 'Remove' button next to the severity. At the bottom are 'Cancel' and 'Save' buttons.

## Dashboard View



## Phases and Actions

### 1. Preparation

- Enable "Audit logon events" (Success/Failure) in secpol.msc on Win 10.
- Configure "Account lockout threshold" in Local Security Policy.
- Disable unused services like RDP or SMB if not required for the VM.

### 2. Detection & Analysis

- Inspect Win 10 Security Log for Event ID 4625.
- Identify the Windows 11 IP/Hostname from the logon event details.
- Check if any "Success" (Event ID 4624) occurred after the failures.

### 3. Containment

- Create an Inbound Firewall Rule on Win 10 to block the Win 11 IP.
- Disconnect the VM network adapter or move to a quarantined VLAN.
- Manually disable the targeted local user if it's not a critical service.

#### 4. Eradication

- Change the password for the targeted local account to a complex one.
- Scan the Win 11 machine for scripts (Hydra, PowerShell) used for the attack.
- Run `net session /delete` to kill any established connections.

#### 5. Recovery

- Re-enable network access after the Win 11 source is cleaned.
- Test the account lockout policy to ensure it triggers correctly now.

#### 6. Lessons Learned & Reporting

- Identify why the attack was possible (e.g., weak password, open RDP).
- Update the incident log with the Win 11/10 details and the MITRE ID.
- Monitor the Win 10 Security logs for 24 hours for any repeats.

#### Success Metrics Table

| Metric                      | Target                                   |
|-----------------------------|------------------------------------------|
| Mean Time to Detect (MTTD)  | <5 Minutes                               |
| Mean Time to Contain (MTTC) | <10 Minutes                              |
| Prevention Rate             | 100% (No successful unauthorized logins) |

#### Analysis Questions and Answers

**1. What is a brute-force attack in a Windows environment?**

*Answer: It is a password-guessing technique targeting accounts over exposed authentication services such as RDP or SMB.*

**2. How does brute force differ from password spraying?**

*Answer: Brute force targets a single account with many passwords, while password spraying tests a single password across multiple accounts.*

**3. What tools or automation methods are commonly used?**

*Answer: Tools such as Hydra, Medusa, Ncrack, or custom PowerShell scripts can automate authentication attempts over RDP or SMB.*

## Unauthorized Scheduled Task (Windows)

### Scenario

The SIEM triggered a critical alert after detecting the creation of a new scheduled task on a Windows 10 VM. Attackers frequently use Scheduled Tasks (T1053.005) to achieve persistence, ensuring their malicious code (in this case, a simulated calc.exe as a backdoor) executes automatically.

### Incident Classification

| Category          | Details                                                        |
|-------------------|----------------------------------------------------------------|
| Incident Type     | Persistence - Unauthorized Scheduled Task                      |
| Severity          | Critical                                                       |
| Priority          | High                                                           |
| Detection Sources | WinEventLog:Security (Event ID 4698), SIEM                     |
| Timestamp         | 21:24:32                                                       |
| Source IP         | 192.168.100.13                                                 |
| Affected Host     | DESKTOP-GU4Q100                                                |
| MITRE ATT&CK      | T1053.005 (Scheduled Task)                                     |
| Tags              | Persistence, Scheduled Task, Windows                           |
| Recommendation    | Audit Task XML, delete suspicious task, and check for C2 comms |

### Alert Rule & Logic

Detection filters for EventCode 4698 OR EventCode 4688 containing schtasks commands.

```
index=* source="WinEventLog:Security"
(EventCode=4698) OR (EventCode=4688 AND (Process_Command_Line="schtasks/create" OR Process_Command_Line="New-ScheduledTask" OR Process_Command_Line="Register-ScheduledTask*))
| eval Method = case(EventCode=4698, "GUI / System API Success",
like(Process_Command_Line, "%schtasks%"), "Command Line (CMD)",
like(Process_Command_Line, "%ScheduledTask%"), "PowerShell", 1=1, "Other")
| stats count, values(TaskName) as Task_Name, values(Process_Command_Line) as CLI_Command, values(SubjectUserName) as User by ComputerName, Method
```

## Alert Settings & Dashboard

The 'Edit Alert' window shows the following configuration:

- Alert:** Unauthorized Scheduled Task Creation Detected
- Description:** This alert triggers whenever a new scheduled task is created on any computer. It monitors all methods of creation, including the Windows GUI, Command Line (CMD),
- Alert type:** Scheduled (selected), Real-time
- Run on Cron Schedule:** (dropdown)
- Time Range:** All time (dropdown)
- Cron Expression:** \*/1 \* \* \* \*  
e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)
- Expires:** 24 (dropdown), hour(s) (dropdown)
- Trigger Conditions:**
  - Trigger alert when:** Number of Results (dropdown)
  - is greater than:** (dropdown) 0 (input)
  - Trigger:** Once (selected), For each result
  - Throttle:** ☐
- Trigger Actions:**
  - + Add Actions:** (dropdown)
  - When triggered:** (dropdown) Add to Triggered Alerts (button) Remove (button)
  - Severity:** Critical (dropdown)

Buttons: Cancel, Save

## Dashboard View

|                          |                                          |                                               |        |           |                                             |
|--------------------------|------------------------------------------|-----------------------------------------------|--------|-----------|---------------------------------------------|
| <input type="checkbox"/> | 2026-02-16 22:19:02 Jordan Standard Time | Unauthorized Scheduled Task Creation Detected | search | Scheduled | <span style="color: red;">●</span> Critical |
|--------------------------|------------------------------------------|-----------------------------------------------|--------|-----------|---------------------------------------------|

## Phases and Actions

### 1. Preparation

- Enable "Audit Other Object Access Events" > "Audit Scheduled Task Creation" in GPO.
- Ensure Event ID 4698 is being ingested into the SIEM from all workstations.
- Maintain a list of authorized scheduled tasks (e.g., GoogleUpdate, Adobe).

### 2. Detection & Analysis

- Confirm if the task `BackdoorTask` was created by a legitimate admin.
- Examine the Task XML (`C:\Windows\System32\Tasks`) for suspicious paths.
- Check if the task points to unusual binaries (e.g., `calc.exe`, `powershell.exe -enc`).

### 3. Containment

- Immediately disable the task using `schtasks /change /tn "BackdoorTask" /disable`.
- If the payload is confirmed malicious, isolate the Win 10 VM from the network.
- Lock the user account if it was used to create the unauthorized task.



#### 4. Eradication

- Completely remove the task: `schtasks /delete /tn "BackdoorTask" /f`.
- Delete any malicious binaries or scripts associated with the task.
- Check registry key `HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Schedule\TaskCache` for leftovers.

#### 5. Recovery

- Verify that no other persistence mechanisms (Startup folder, Services) were created.
- Revert to the last clean VM snapshot if multiple artifacts are found.
- Set a specific watch-list for the Affected Host for the next 7 days.

#### 6. Lessons Learned & Reporting

- How did the Windows 11 machine gain the credentials to create a task on Win 10?
- Enforce "Least Privilege" to prevent non-admin users from creating scheduled tasks.
- Finalize report including the specific CLI command used in the simulation.

#### Success Metrics Table

| Metric                      | Target                             |
|-----------------------------|------------------------------------|
| Mean Time to Detect (MTTD)  | <2 Minutes                         |
| Mean Time to Contain (MTTC) | <15 Minutes                        |
| Detection Accuracy          | 100% (Confirmed via Event ID 4698) |

#### Analysis Questions and Answers

**1. Why do attackers use scheduled tasks?**

*Answer: To achieve persistence by automatically executing malicious code after reboots or user logons.*

**2. Which Event ID identifies scheduled task creation?**

*Answer: Event ID 4698 in Windows Security Logs.*

**3. How can you verify the action of a suspicious task?**

*Answer: By inspecting the "Actions" tab in Task Scheduler or analyzing the XML data in Event 4698.*

## Registry Persistence (Windows)

### Scenario

The SIEM triggered an alert for a suspicious modification to the Windows Registry "Run" key on the Windows 10 VM. A non-system account was detected adding a new value named "Updater" pointing to an executable in a temporary folder, indicating an attempt to achieve Boot/Logon Autostart Persistence (T1547.001).

### Incident Classification

| Category          | Details                                                     |
|-------------------|-------------------------------------------------------------|
| Incident Type     | Persistence - Registry Run Key                              |
| Severity          | Medium                                                      |
| Priority          | High                                                        |
| Detection Sources | Windows Security Logs (Event ID 4657), Sysmon (Event ID 13) |
| Tags              | Registry, Persistence, Run Key, Windows                     |
| MITRE ATT&CK      | T1547.001                                                   |
| Recommendation    | Remove malicious registry entry and quarantine binary       |

### Alert Rule & Logic

Detects modifications to CurrentVersion\Run or RunOnce keys where the user is not a standard System/Service account.

```
index=* EventCode IN (4656, 4657, 4660, 4663) TaskCategory=Registry|
| rex "Account\s+Name:\s+(?<AccName>[^\r\n]+)"
| eval User=mvindeX(AccName, 0)
| rename "Process Name" as Tool, "Object Name" as Registry_Key
| search NOT (User="SYSTEM" OR User="*$" OR User="LOCAL SERVICE" OR User="NETWORK SERVICE")
```

## Alert Settings & Dashboard

**Edit Alert**

Alert: **User-Driven Registry Modification Detected**

Description: Detects manual or non-system modifications to the Windows Registry (EventCodes 4656, 4657, 4660, 4663). This alert filters out noise from 'SYSTEM' and 'Machine'.

Alert type: **Scheduled** | Real-time

Run on Cron Schedule ▾

Time Range: **All time** ▸

Cron Expression: **\*/\* \* \* \***  
e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)

Expires: **24** | hour(s) ▾

**Trigger Conditions**

Trigger alert when: **Number of Results** ▾

**is greater than** ▾ **0**

Trigger: **Once** | For each result

Throttle ? ☐

**Trigger Actions**

+ Add Actions ▾

When triggered ▾

Severity: **Medium** ▾

[Remove](#)

**Cancel** **Save**

## Dashboard View

|                                          |                                            |        |           |          |            |
|------------------------------------------|--------------------------------------------|--------|-----------|----------|------------|
| 2026-02-16 17:58:01 Jordan Standard Time | User-Driven Registry Modification Detected | search | Scheduled | ● Medium | Per Result |
|------------------------------------------|--------------------------------------------|--------|-----------|----------|------------|

## Phases and Actions

### 1. Preparation

- Enable **Audit Registry** (Success) in `secpol.msc` > Advanced Audit Policy Configuration.
- Configure SACLs on sensitive keys (Run/RunOnce) to generate Event ID 4657.
- Document legitimate software that uses Run keys (e.g., OneDrive, SecurityHealth).

### 2. Detection & Analysis

- Confirm if the value `Updater` and data `C:\temp\malware.exe` are unauthorized.
- Identify which process made the change (e.g., `cmd.exe`, `powershell.exe`, or a malicious binary).
- Locate `C:\temp\malware.exe` and check its hash on VirusTotal.

### 3. Containment

- Kill the process that modified the registry key if it is still running.
- Temporarily restrict the user from making further registry changes.
- Isolate the Win 10 VM if the `malware.exe` is confirmed to be communicating externally.

#### 4. Eradication

- Delete the key: `reg delete "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "Updater" /f`.
- Securely delete `C:\temp\malware.exe` and any other files in the temp directory.
- Check HKLM (Local Machine) equivalent keys for similar unauthorized entries.

#### 5. Recovery

- Restart the VM and verify that the "Updater" task does not reappear.
- Perform a full EDR/Antivirus scan on the Win 10 VM.
- Ensure the user profile hasn't been used to create other persistence points.

#### 6. Lessons Learned & Reporting

- Analyze how the attacker executed the `reg add` command (Remote CMD/PowerShell?).
- Use GPO to restrict users from writing to certain Registry hives if not required.
- Log the command, the attacker's IP, and the target key for the final report.

#### Success Metrics Table

| Metric                      | Target                             |
|-----------------------------|------------------------------------|
| Mean Time to Detect (MTTD)  | <5 Minutes                         |
| Mean Time to Contain (MTTC) | <10 Minutes                        |
| Persistence Block Rate      | 100% (No reboot-survival achieved) |

#### Analysis Questions and Answers

**1. Which registry keys are commonly targeted for persistence?**

*Answer: Run keys in HKEY\_LOCAL\_MACHINE or HKEY\_CURRENT\_USER.*

**2. How can unauthorized registry changes be detected?**

*Answer: Monitoring via Sysmon Event ID 13 or auditing tools.*

**3. What is the remediation?**

*Answer: Delete malicious keys and validate system integrity.*

## Privilege Escalation (Windows)

### Scenario

The SIEM has detected the unauthorized addition of a new user (testuser) to the local Administrators security group on the Windows 10 VM. This activity, performed by the user account 3more, indicates a successful attempt to escalate privileges to gain full system control and bypass security restrictions.

### Incident Classification

| Category          | Details                                                     |
|-------------------|-------------------------------------------------------------|
| Incident Type     | Privilege Escalation - Local Group Manipulation             |
| Severity          | High                                                        |
| Priority          | High                                                        |
| Detection Sources | Windows Security Logs (Event ID 4732)                       |
| Timestamp         | 18:21:02                                                    |
| Subject User      | 3more (Account performing the change)                       |
| New Admin User    | testuser (Account being promoted)                           |
| Affected Hosts    | DESKTOP-GU4Q100                                             |
| MITRE ATT&CK      | T1078.003 (Local Accounts), T1098 (Account Manipulation)    |
| Tags              | Privilege Escalation, Persistence, Local Admin, Windows     |
| Recommendation    | Immediately remove 'testuser' from the Administrators group |

### Alert Rule & Logic

Monitors for Event ID 4732 where the Target Group SID matches S-1-5-32-544 (The built-in SID for Local Administrators).

```
index=main EventCode=4732 "Administrators"
```

## Alert Settings & Dashboard

**Edit Alert**

Alert: **Privilege Escalation - New Member Added to Administrators**

Description: Monitors for accounts added to the "Administrators" group. This indicates an attempt to gain full system control.

Alert type: **Scheduled** **Real-time**

Run on Cron Schedule ▾

Time Range: **All time** ▾

Cron Expression: **\*/\* \* \* \* \***  
e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)

Expires: **24** **hour(s)** ▾

**Trigger Conditions**

Trigger alert when: **Number of Results** ▾

**is greater than** ▾ **0**

Trigger: **Once** **For each result**

Throttle ? ☐

**Trigger Actions**

**+ Add Actions** ▾

When triggered ▾

**Add to Triggered Alerts** [Remove](#)

Severity: **High** ▾

**Cancel** **Save**

## Dashboard View

2026-02-16 18:21:02 Jordan Standard Time    Privilege Escalation - New Member Added to Administrators    search    Scheduled    ● High    Per Result

## Phases and Actions

### 1. Preparation

- Enable "Audit Security Group Management" (Success/Failure) in `secpol.msc > Advanced Audit Policy Configuration > Account Management`.
- Use GPO (Group Policy) to enforce specific members in the Administrators group.
- Ensure Event ID 4732 is forwarded from all Windows 10 endpoints.

### 2. Detection & Analysis

- Identify the Subject User (the one who ran the command) and the New Member.
- Determine if the change was made via CMD (`net localgroup`), PowerShell, or GUI.
- Check if the same Subject User has added admins to other machines in the network.

### 3. Containment

- Immediately remove the unauthorized user: `net localgroup Administrators testuser /delete`.

- Disable the Subject User (3more) account until the investigation is complete.
- Isolate the Win 10 VM to prevent the new admin from disabling security tools remotely.

#### 4. Eradication

- If `testuser` is entirely unauthorized, delete the account from the system.
- Force a password reset for all local admin accounts on the affected host.
- Check for tools like Mimikatz or PCHunter that might have been used after escalation.

#### 5. Recovery

- Perform a full audit of all local groups on the Win 10 VM to ensure no other "backdoor" groups were modified.
- Re-apply GPO settings to ensure the Administrators group is reverted to its baseline.
- Monitor for any new 4732 events on this host for the next 48 hours.

#### 6. Lessons Learned & Reporting

- How did 3more get the permissions to add a new admin? Was 3more already an admin?
- Recommend removing administrative rights from standard user accounts.
- Document the timeline from the `net localgroup` command to the containment step.

#### Success Metrics Table

| Metric                      | Target                                    |
|-----------------------------|-------------------------------------------|
| Mean Time to Detect (MTTD)  | <1 Minute (Real-time Cron)                |
| Mean Time to Contain (MTTC) | <10 Minutes                               |
| Unauthorized Admin Uptime   | <15 Minutes (Time user held admin rights) |

#### Analysis Questions and Answers

**1. How can attackers escalate privileges?**

*Answer: Exploiting misconfigured permissions, unpatched vulnerabilities, or admin group abuse.*

**2. Which logs help detect escalation?**

*Answer: Security Event Logs (Event ID 4672) for admin privilege assignments.*

**3. Immediate mitigation?**

*Answer: Isolate the system, revoke unauthorized privileges, investigate activity.*

## Successful RDP Access (Windows)

### Scenario

The SIEM has detected a successful Remote Desktop (RDP) connection to the Windows 10 VM. This alert triggered based on a Logon Type 10, indicating a new remote interactive session established by user 3more. Unauthorized RDP access is a primary indicator of an attacker moving laterally through the network.

### Incident Classification

| Category          | Details                                                        |
|-------------------|----------------------------------------------------------------|
| Incident Type     | Lateral Movement - Remote Desktop Protocol                     |
| Severity          | High                                                           |
| Priority          | High                                                           |
| Detection Sources | Windows Security Logs (Event ID 4624)                          |
| Timestamp         | 16:49:32                                                       |
| User Account      | 3more                                                          |
| Source IP         | 172.28.183.132 (Attacker Windows 11)                           |
| Affected Hosts    | DESKTOP-GU4Q100 (Target Windows 10)                            |
| MITRE ATT&CK      | T1021.001 (Remote Services: Remote Desktop Protocol)           |
| Tags              | Lateral Movement, Remote Access, RDP                           |
| Recommendation    | Verify user authorization and check for Jump Server compliance |

### Alert Rule & Logic

Monitors for Event ID 4624 with LogonType 10 (New RDP) or LogonType 7 (Re-connection/Unlock).

```
index=main EventCode=4624
| rex field=_raw "Logon Type:\s+(?<LType>\d+)"
| where LType=10 OR LType=7
| eval Access_Method=case(LType=10, "New Remote Desktop Session", LType=7, "Remote Session Unlock")
| table _time, ComputerName, TargetUserName, Source_Network_Address, Access_Method
| rename ComputerName as "Target_Machine", TargetUserName as "User", Source_Network_Address as "Attacker_IP"
```



## Alert Settings & Dashboard

**Edit Alert** [X]

Alert: **Successful RDP Access Detection (New or Reconnect)**

Description: Detects when a user logs in via RDP (Type 10) or unlocks an existing remote session (Type 7).

Alert type: **Scheduled** | Real-time

Run on Cron Schedule ▾

Time Range: All time ▾

Cron Expression: \*/1 \* \* \* \*  
e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)

Expires: **24** | hour(s) ▾

**Trigger Conditions**

Trigger alert when: Number of Results ▾

is greater than ▾ 0

Trigger: **Once** | For each result

Throttle ? ☐

**Trigger Actions**

+ Add Actions ▾

When triggered ▾

- Add to Triggered Alerts [Remove](#)
- Severity: **High** ▾

Cancel Save

## Dashboard View

2026-02-16 16:49:32 Jordan Standard Time      Successful RDP Access Detection (New or Reconnect)      search      Scheduled      ● High

## Phases and Actions

### 1. Preparation

- Ensure Network Level Authentication (NLA) is enabled for RDP.
- Use "Allow log on through Remote Desktop Services" to limit RDP to specific users.
- Implement Multi-Factor Authentication (MFA) for all remote sessions.

### 2. Detection & Analysis

- Distinguish between Type 10 (Fresh start) and Type 7 (Existing session unlock).
- Verify if the Source IP (172.28.183.132) belongs to an authorized admin or a jump host.
- Monitor what the user does after logging in (e.g., opening CMD or Registry).

### 3. Containment

- Disconnect the user immediately via `rwinsta` or Task Manager.
- Restrict Port 3389 (RDP) on the Win 10 VM to allow only specific trusted IPs.
- If the login is confirmed as malicious, disable the account **3more**.

#### 4. Eradication

- Reset the password for the compromised user account.
- Check if the attacker tried to clear event logs to hide the RDP entry.
- Check for "Sticky Keys" backdoors (`sethc.exe`) often installed after RDP access.

#### 5. Recovery

- Re-enable RDP access only through a secured VPN or Jump Server.
- Verify that no unauthorized software was installed during the RDP session.
- Set an alert for any RDP connection attempts from outside the local subnet.

#### 6. Lessons Learned & Reporting

- Was the RDP access possible due to weak credentials or an exposed port?
- Recommend placing VMs in a separate VLAN from standard workstations.
- Document the Source IP, duration of the session, and actions taken.

#### Success Metrics Table

| Metric                      | Target                              |
|-----------------------------|-------------------------------------|
| Mean Time to Detect (MTTD)  | <1 Minute                           |
| Mean Time to Contain (MTTC) | <5 Minutes                          |
| MFA Compliance              | 100% (All remote sessions verified) |

#### Analysis Questions and Answers

**1. What logs RDP access?**

*Answer: Windows Security Log, Event ID 4624.*

**2. How to detect unauthorized RDP logins?**

*Answer: Review source IPs, times, and account usage patterns.*

**3. What immediate action is required?**

*Answer: Isolate machine, reset credentials, and block malicious IP.*

## Security Event Log Cleared (AD)

### Scenario

The SIEM has detected that the Security Event Log was manually cleared on the Primary Domain Controller (PDC10.test.local). This activity was performed by the Administrator account. Clearing logs is a high-confidence indicator of Defense Evasion (T1070.001), typically used by attackers to destroy forensic evidence of lateral movement or credential dumping.

### Incident Classification

| Category          | Details                                                       |
|-------------------|---------------------------------------------------------------|
| Incident Type     | Defense Evasion - Log Clearing                                |
| Severity          | Critical                                                      |
| Priority          | High                                                          |
| Detection Sources | Windows Security Logs (Event ID 1102)                         |
| Timestamp         | 01:22:01                                                      |
| Affected Host     | PDC10.test.local                                              |
| Source IP         | 192.168.0.158                                                 |
| MITRE ATT&CK      | T1070.001                                                     |
| Tags              | Domain Controller, Log Clearing, Defense Evasion              |
| Recommendation    | Isolate DC, reset compromised account, recover logs from SIEM |

### Alert Rule & Logic

Monitors for Event ID 1102 (The audit log was cleared) specifically on critical infrastructure like Domain Controllers.

#### New Search

```
index=main EventCode=1102 OR (EventCode=104 AND SourceName="Microsoft-Windows-Eventlog")
| table _time, ComputerName, Account_Name, LogName, Message
| rename AccountName as "Administrator" , Message as "The audit log was cleared" ,
LogName as "Security ",ComputerName as "PDC10.test.local"
```

## Alert Settings & Dashboard

Save As Alert

Settings

Title

Security Event Log Cleared (AD)

Description

The "clean up" phase. The attacker wipes the security logs to delete all traces of the previous 7 steps.

Permissions

Private Shared in App

Alert type

Scheduled Real-time

Run on Cron Schedule ▾

Time Range

Last 24 hours ▶

Cron Expression

\*/1 \* \* \* \*

e.g. 00 18 \*\*\* (every day at 6PM). [Learn More](#)

Expires

24 hour(s) ▾

Trigger Conditions

Trigger alert when

Number of Results ▾

is greater than ▾ 0

Trigger

Once For each result

Throttle ?

☐

Trigger Actions

+ Add Actions ▾

When triggered

▼

🔔 Add to Triggered Alerts

Remove

Severity

Critical ▾

## Dashboard View

splunk-enterprise Apps ▾

Triggered Alerts

Filter

App Search & Report... Owner All owners ▾ Severity All severity ▾ Alert name All alerts ▾

| <input type="checkbox"/> | Time                    | Alert name                      | App    | Type      | Severity |
|--------------------------|-------------------------|---------------------------------|--------|-----------|----------|
| <input type="checkbox"/> | 2025-02-18 01:22:01 +03 | Security Event Log Cleared (AD) | search | Scheduled | Critical |

## Phases and Actions

### 1. Preparation

- Ensure "Audit System Events" is enabled in the Default Domain Controllers Policy.
- Verify logs are forwarded to SIEM in real-time (so they are safe if local logs are wiped).
- Restrict "Manage auditing and security log" rights to a very small group of users.

### 2. Detection & Analysis

- Confirm Event ID 1102 in the SIEM (since local logs on PDC10 are now empty).
- Determine if the "Administrator" account was used via RDP, PowerShell, or locally.

- Check SIEM for activities occurring immediately before 01:22:01 to see what the attacker hid.

### 3. Containment

- Immediately isolate PDC10.test.local at the network level to prevent further evasion.
- Temporarily disable or reset the password for the Administrator account.
- Terminate all active RDP, SMB, and WinRM sessions on the affected Domain Controller.

### 4. Eradication

- Perform a forced password change for ALL high-privilege/Domain Admin accounts.
- Scan for backdoors (Scheduled Tasks, Services) installed before the log was cleared.
- Run `net session /delete` to ensure no attacker connections remain.

### 5. Recovery

- Re-enable DC access only after a full forensic clean-up and verification.
- Confirm that new logs are being generated and successfully forwarded to the SIEM.
- Monitor the DC for 24-48 hours for any signs of re-entry or further evasion.

### 6. Lessons Learned & Reporting

- Identify how the attacker gained the high-level privileges needed to clear logs.
- Implement "Protected Users" group for sensitive accounts like Administrator.
- Document the affected DC, the compromised account, and the T1070.001 mapping.

### Success Metrics Table

| Metric                      | Target                                          |
|-----------------------------|-------------------------------------------------|
| Mean Time to Detect (MTTD)  | <1 Minute (Critical Alert)                      |
| Mean Time to Contain (MTTC) | <15 Minutes                                     |
| Log Recovery Rate           | 100% (Logs retrieved from SIEM/Off-site backup) |

### Analysis Questions and Answers

**1. Which Event IDs indicate log clearing?**

*Answer: Event ID 1102 in Windows Security Logs.*

**2. Why do attackers clear logs?**

*Answer: To remove traces of malicious activity.*

**3. How can log clearing be detected?**

*Answer: Monitor for sudden gaps in logs or Event ID 1102 alerts.*

## Windows Service Creation (AD)

### Scenario

The SIEM has detected the installation of a new Windows service (MaliciousService) on the Primary Domain Controller (PDC10.test.local). The alert specifically flagged this service because its executable path resides in a non-standard directory. Attackers use this method to achieve Persistence (T1543.003) and run malicious code with the highest possible local privileges (SYSTEM).

### Incident Classification

| Category          | Details                                                       |
|-------------------|---------------------------------------------------------------|
| Incident Type     | Persistence - New Service Creation                            |
| Severity          | Critical                                                      |
| Priority          | High                                                          |
| Detection Sources | Windows System Event Logs (Event ID 7045)                     |
| Timestamp         | 00:57:01                                                      |
| Source IP         | 192.168.0.158                                                 |
| Affected Hosts    | PDC10.test.local                                              |
| MITRE ATT&CK      | T1543.003 (Windows Service)                                   |
| Tags              | Persistence, Privilege Escalation, New Service                |
| Recommendation    | Stop service, delete entry, and quarantine binary immediately |

### Alert Rule & Logic

Filters for Event ID 7045 where the ImagePath does NOT contain standard paths (e.g., System32, Program Files).

```
index=main EventCode=7045
| where NOT (Service_File_Name LIKE "%Windows\System32%" OR Service_File_Name LIKE "%Program Files%")
| table _time, ComputerName, Service_Name, Service_File_Name, Service_Account
```

## Alert Settings & Dashboard

Save As Alert

×

Settings

Title

Windows Service Creation (AD)

Description

A new windows service was created using a file in a temp folder. This is a common sign of a hacker or malware trying to stay on the system, as real programs almost never run services from temporary folders.

Permissions

Private

Shared in App

Alert type

Scheduled

Real-time

Run on Cron Schedule ▼

Time Range

Last 24 hours ▶

Cron Expression

\*/\* \* \* \*

e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)

Expires

24

hour(s) ▼

Trigger Conditions

Trigger alert when

Number of Results ▼

is greater than ▼

0

Trigger

Once

For each result

Throttle ?

☐

Trigger Actions

+ Add Actions ▼

When triggered

▼

🔔 Add to Triggered Alerts

Remove

Severity

Critical ▼

Cancel

Save

## Dashboard View

| splunk-enterprise Apps                           |                               |                    |           |              |            |
|--------------------------------------------------|-------------------------------|--------------------|-----------|--------------|------------|
| Triggered Alerts                                 |                               |                    |           |              |            |
| Filter                                           | App                           | Search & Report... | Owner     | All owners   | Severity   |
|                                                  |                               |                    |           | All severity | All alerts |
| Time                                             | Alert name                    | App                | Type      | Severity     |            |
| <input type="checkbox"/> 2026-02-18 00:57:01 +03 | Windows Service Creation (AD) | search             | Scheduled | Critical     |            |

## Phases and Actions

### 1. Preparation

- Enable "Audit Service Creation" in the Default Domain Controllers GPO.
- Maintain a whitelist of authorized third-party service paths.
- Ensure EDR is active to monitor the execution of the service binary.

## 2. Detection & Analysis

- Inspect the System Log for Event ID 7045.
- Locate the file path (e.g., `C:\Windows\Temp\malicious.exe`) and check for masquerading.
- Verify if the LocalSystem account or a Domain Admin account authorized the service.

## 3. Containment

- Immediately stop the service: `sc stop MaliciousService` or `Stop-Service`.
- Move the service executable to an isolated folder for forensic analysis.
- Disconnect PDC10.test.local from the network to prevent further lateral movement.

## 4. Eradication

- Completely remove the service entry: `sc delete MaliciousService`.
- Delete any temporary files, scripts, or installer logs associated with the service.
- Inspect `HKLM\SYSTEM\CurrentControlSet\Services` for any leftover keys.

## 5. Recovery

- Restore from backup if the service binary replaced or patched a core system file.
- Run `sfc /scannow` to ensure no system binaries were tampered with.
- Watch for 24 hours for any scripts attempting to recreate the service.

## 6. Lessons Learned & Reporting

- Identify how the attacker gained the rights to install a system service.
- Enforce AppLocker or Software Restriction Policies to block execution from non-standard paths.
- Document the service name, binary path, and the compromised account used.

### Success Metrics Table

| Metric                      | Target                       |
|-----------------------------|------------------------------|
| Mean Time to Detect (MTTD)  | <2 Minutes                   |
| Mean Time to Contain (MTTC) | <10 Minutes                  |
| False Positive Rate         | <10% (due to path filtering) |



## Analysis Questions and Answers

**1. Why create unauthorized services?**

*Answer: To achieve persistence and potentially escalate privileges.*

**2. Which Event ID logs service creation?**

*Answer: Event ID 7045 in System logs.*

**3. Remediation steps?**

*Answer: Remove the service, investigate source, and isolate affected systems.*

## AD Database Extraction - Domain Compromise (AD)

### Scenario

The SIEM has detected the unauthorized execution of ntdsutil.exe on the Primary Domain Controller (PDC10.test.local). The command arguments indicate an attempt to create an "Install from Media" (IFM) snapshot. This is a critical technique used for OS Credential Dumping (T1003.003), allowing attackers to steal the entire Active Directory database for offline cracking.

### Incident Classification

| Category          | Details                                                      |
|-------------------|--------------------------------------------------------------|
| Incident Type     | Credential Access - NTDS Extraction                          |
| Severity          | CRITICAL / EMERGENCY                                         |
| Priority          | Emergency (Total Domain Compromise)                          |
| Detection Sources | Windows Security Log (Event ID 4688), EDR                    |
| Timestamp         | 00:10:00                                                     |
| Source IP         | 192.168.0.158                                                |
| Affected Hosts    | PDC10.test.local                                             |
| MITRE ATT&CK      | T1003.003 (NTDS Extraction)                                  |
| Tags              | Domain Compromise, Credential Theft, ntdsutil                |
| Recommendation    | Isolate DC, Reset KRBGTG twice, and audit all Admin accounts |

### Alert Rule & Logic

Monitors for Process Creation (4688) where the process name is ntdsutil.exe and the command line contains "create full" or "ifm".

```
index=main EventCode=4688 New_Process_Name="*\ntdsutil.exe"
| where (Process_Command_Line LIKE "%ac i ntds%" AND Process_Command_Line LIKE "%create full%")
| table _time, ComputerName, Account_Name, Process_Command_Line, New_ProcessName
```

## Alert Settings & Dashboard

Save As Alert

Settings

Title

AD Database Extraction - Domain Compromise

Description

On a domain controller attackers use ntdsutil to create a copy of the AD database. This file contains the hashes of every user in the entire organization.

Permissions

Private Shared in App

Alert type

Scheduled Real-time

Run on Cron Schedule

Time Range

Last 24 hours

Cron Expression

\* \* \* \* \*

e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)

Expires

24 hour(s)

Trigger Conditions

Trigger alert when

Number of Results

is greater than

0

Trigger

Once For each result

Throttle ?

Trigger Actions

+ Add Actions

When triggered

Add to Triggered Alerts

Remove

Severity

Critical

Cancel

Save

## Dashboard View

splunk

enterprise

Apps

Administrator

Messages

Settings

Activity

Help

Find

Triggered Alerts

Filter

App

Search & Report

Owner

All owners

Severity

All severity

Alert name

All alerts

Showing 1 of 1 results

Show 20 per page

1 of 1 pages

| <input type="checkbox"/> | Time                    | Alert name                                 | App    | Type      | Severity | Mode   | Actions                                                                             |
|--------------------------|-------------------------|--------------------------------------------|--------|-----------|----------|--------|-------------------------------------------------------------------------------------|
| <input type="checkbox"/> | 2026-02-18 00:10:00 +03 | AD Database Extraction - Domain Compromise | search | Scheduled | Critical | Digest | <a href="#">View Results</a>   <a href="#">Edit Search</a>   <a href="#">Delete</a> |

## Phases and Actions

### 1. Preparation

- Ensure "Include command line in process creation events" is enabled via GPO.
- Use AppLocker or WDAC to block ntdsutil.exe for everyone except specific recovery accounts.
- Create a folder named C:\NTDS\_Backup and set an alert for any access to it.

### 2. Detection & Analysis

- Verify if the command was part of an authorized recovery drill (unlikely).
- Inspect the target path (e.g., C:\temp) for ntds.dit and the SYSTEM registry hive.

- Check Network logs (NDR) for large data transfers from the DC to 192.168.0.158.
- Identify the source of the Administrator login (RDP, WinRM, or physical).

### 3. Containment

- Immediately isolate PDC10.test.local from the network.
- Terminate all active ntdsutil.exe and cmd.exe processes on the DC.
- Block the Attacker IP (192.168.0.158) at the firewall level.

### 4. Eradication

- Securely wipe the extracted ntds.dit files from the staging directory.
- Initiate the double-reset of the KRTGT account password (with 24h interval).
- Force a password reset for all Domain Admin and service accounts.

### 5. Recovery

- Check for Scheduled Tasks or new Services created during the admin session.
- Take a full disk image of the DC for deeper forensic analysis before cleanup.
- Enable verbose logging for any process accessing the C: Windows NTDS folder..

### 6. Lessons Learned & Reporting

- Identify the "Attack Path" (how the attacker became a Domain Admin).
- Recommend Privileged Access Workstations to prevent credential theft.
- Document the complete timeline of the Domain Compromise attempt.

### Success Metrics Table

| Metric                      | Target                   |
|-----------------------------|--------------------------|
| Mean Time to Detect (MTTD)  | <2 Minutes               |
| Mean Time to Isolate (MTTI) | <15 Minutes              |
| KRTGT Reset Status          | Completed (Double Reset) |

### Analysis Questions and Answers

**1. What sensitive data is in NTDS.dit?**

*Answer: Active Directory user accounts and password hashes.*

**2. Tools for extraction?**

*Answer: ntdsutil.exe, vssadmin, or shadow copy techniques.*

**3. Critical recovery step?**

*Answer: Reset KRBTGT password twice to invalidate tickets.*

## Remote Command Execution (AD)

### Scenario

The SIEM has detected active lateral movement using Windows Management Instrumentation (WMI). An attacker is leveraging wmiPrvSE.exe to spawn remote shells (cmd.exe or powershell.exe) on the Target Host (192.168.0.164) and the Domain Controller (PDC10). This allows for remote command execution without dropping a binary to disk, facilitating stealthy movement across the domain.

### Incident Classification

| Category          | Details                                                             |
|-------------------|---------------------------------------------------------------------|
| Incident Type     | Lateral Movement - Remote Execution (WMI)                           |
| Severity          | Critical                                                            |
| Priority          | High (Active Movement)                                              |
| Detection Sources | Windows Security Log (Event 4688), WMI-Activity Logs                |
| Timestamp         | 23:44:01                                                            |
| Source IP         | 192.168.0.158                                                       |
| Affected Hosts    | 192.168.0.164 (Target), PDC10.test.local                            |
| MITRE ATT&CK      | T1047 (Windows Management Instrumentation)                          |
| Tags              | Lateral Movement, Remote Execution, WmiPrvSE                        |
| Recommendation    | Isolate affected hosts, rotate Admin passwords, and block RPC ports |

### Alert Rule & Logic

Detects wmiPrvSE.exe (The WMI Provider Host) as a parent process spawning cmd.exe or powershell.exe.

```
index=main EventCode=4688 Creator_Process_Name="*WmiPrvSE.exe"
| rename New_Process_Name as Executed_Process, Process_Command_Line as Full_Command, Account_Name as Used_Account
| search Executed_Process IN ("*cmd.exe", "*powershell.exe", "*rundll32.exe", "*calc.exe")
| table _time, host, Used_Account, Executed_Process, Full_Command
```

## Alert Settings & Dashboard

Edit alert

×

Alert title

Remote Command Execution (AD)

Description

Detects lateral movement attempts using remote command execution tools such as PsExec or WMIC to run commands on remote systems.

Schedule & trigger conditions

Trigger actions

\* Alert type

Scheduled

Real-time

\* Schedule

Cron Expression

Run

On Cron Schedule

\*/1 \* \* \* \*

e.g. 0 18 \* \* \* (every day at 6PM). [Learn more](#)

\* Time range

Last 24 hours

Expires after

24

hour(s)

\* Trigger alert when

Number of results

is greater than

0

\* Trigger frequency

Once

For each result

Turn on throttle

☐

If throttle is on, then after an alert is triggered, subsequent alerts are suppressed for the duration of the throttle period. [Throttle alerts documentation](#)

Cancel

Save

## Dashboard View

|                         |                               |                    |           |            |          |                                     |            |            |                              |
|-------------------------|-------------------------------|--------------------|-----------|------------|----------|-------------------------------------|------------|------------|------------------------------|
| Splunk Enterprise       |                               |                    |           |            |          |                                     |            |            |                              |
| Triggers Alerts         |                               |                    |           |            |          |                                     |            |            |                              |
| Filter                  | App                           | Search & Report... | Owner     | All owners | Severity | All severity                        | Alert name | All alerts | Showing 1 - 20 of 96 results |
| Time                    | Alert name                    | App                | Type      | Severity   | Mode     | Actions                             |            |            |                              |
| 2026-02-17 23:44:01 +03 | Remote Command Execution (AD) | search             | Scheduled | Critical   | Digest   | View Results   Edit Search   Delete |            |            |                              |

## Phases and Actions

### 1. Preparation

- Enable Microsoft-Windows-WMI-Activity/Operational logs to trace the caller's IP.
- Restrict RPC (TCP 135) and dynamic ports to authorized Admin Jump Hosts only.
- Audit "Remote Management Users" group to ensure no standard users have access.

### 2. Detection & Analysis

- Check WMI-Activity Event ID 5858 to find the IP address of the machine that initiated the call.

- Decode any Base64 PowerShell commands to check for backdoors or credential harvesters.
- Search for similar WMIPrvSE.exe patterns across all workstations in the last 4 hours.

### 3. Containment

- Isolate the Source (192.168.0.158) and Targets (192.168.0.164/PDC10).
- Kill any orphaned cmd.exe or powershell.exe processes spawned by WMI.
- Block Port 135 and Port 445 between the affected VLAN segments immediately.

### 4. Eradication

- Delete any staging files (e.g., proof.txt, temp.ps1) created by the attacker.
- Perform immediate rotation of Domain Admin and LAPS passwords.
- Run `Get-WMIObject -Namespace root\subscription` to find malicious event filters.

### 5. Recovery

- Deploy a GPO to disable WinRM and WMI remote access if not strictly required.
- Re-enable network access only after verifying "Patient Zero" is clean.
- Set alerts for Logon Type 3 (Network) followed immediately by a WMI process spawn.

### 6. Lessons Learned & Reporting

- Identify how the attacker gained the admin credentials required for WMI execution.
- Implement a Tiered Administrative Model to prevent Admins from logging into standard workstations.
- Document the lateral movement path and the specific WMI commands utilized.

### Success Metrics Table

| Metric                     | Target                           |
|----------------------------|----------------------------------|
| Mean Time to Detect (MTTD) | <5 Minutes                       |
| Containment Rate           | 100% (No further lateral spread) |
| Credential Rotation        | <30 Minutes from confirmation    |

### Analysis Questions and Answers

**1. How can RCE occur in AD?**

*Answer: Through compromised accounts or misconfigured services.*

**2. Which logs indicate RCE activity?**

*Answer: Security logs for remote logon and process creation events (e.g., 4624, 4688).*

**3. Mitigation?**

*Answer: Disable compromised accounts, isolate affected systems, review audit logs.*

## SMB Share Enumeration (AD)

### Scenario

The SIEM has detected a high volume of network share access events (Event ID 5140) originating from a single source (192.168.0.158). This behavior is consistent with automated Network Share Discovery (T1135). The attacker is likely searching for sensitive data or open shares to facilitate lateral movement within the test.local environment.

### Incident Classification

| Category          | Details                                                      |
|-------------------|--------------------------------------------------------------|
| Incident Type     | Discovery - Network Share Enumeration                        |
| Severity          | High                                                         |
| Priority          | Medium (Information Gathering Phase)                         |
| Detection Sources | Windows Security Logs (Event ID 5140), SIEM                  |
| Timestamp         | 22:10:01                                                     |
| Source IP         | 192.168.0.158                                                |
| Affected Hosts    | PDC10.test.local (and surrounding file servers)              |
| MITRE ATT&CK      | T1135 (Network Share Discovery)                              |
| Tags              | Discovery, Enumeration, SMB, Network Scan                    |
| Recommendation    | Isolate Source IP and enforce Access-Based Enumeration (ABE) |

### Alert Rule & Logic

Detects an anomaly where a single IP address accesses more than 20 unique network shares within a 1-minute window (Event ID 5140).

```
index=main EventCode=5140
| stats count, min(_time) as first_time, max(_time) as last_time, values(Share_Name) as accessed_shares, values(Account_Name) as user_name by Source_Address
| where count >= 1
| fieldformat first_time=strftime(first_time, "%Y-%m-%d %H:%M:%S")
| fieldformat last_time=strftime(last_time, "%Y-%m-%d %H:%M:%S")
| rename Source_Address as "Attacker_IP", count as "Total_Events"
```



## Alert Settings & Dashboard

Save As Alert

Settings

Title

SMB Share Enumeration (AD)

Description

Detects scanning and enumeration of shared folders using commands such as net view to discover accessible network resources.

Permissions

Private

Shared in App

Alert type

Scheduled

Real-time

Run on Cron Schedule

Time Range

Last 24 hours

Cron Expression

\*/1 \* \* \* \*

e.g. 00 18 \*\*\* (every day at 6PM). [Learn More](#)

Expires

24

hour(s)

Trigger Conditions

Trigger alert when

Number of Results

is greater than

0

Trigger

Once

For each result

Throttle

☐

Trigger Actions

+ Add Actions

When triggered

▼

Add to Triggered Alerts

Remove

## Dashboard View

|                         |                            |                 |           |            |          |                                     |            |            |                            |
|-------------------------|----------------------------|-----------------|-----------|------------|----------|-------------------------------------|------------|------------|----------------------------|
| Triggered Alerts        |                            |                 |           |            |          |                                     |            |            |                            |
| Filter                  | App                        | Search & Report | Owner     | All owners | Severity | All severity                        | Alert name | All alerts | Showing 1 - 1 of 1 results |
| Time                    | Alert name                 | App             | Type      | Severity   | Mode     | Actions                             |            |            |                            |
| 2026-02-17 22:10:01 +03 | SMB Share Enumeration (AD) | search          | Scheduled | Medium     | Digest   | View Results   Edit Search   Delete |            |            |                            |

## Phases and Actions

### 1. Preparation

- Enable "Audit Detailed File Share" in GPO to ensure Event ID 5140 is generated.
- Enable Access-Based Enumeration (ABE) so users cannot see folders they don't have permissions for.
- Enforce SMB Signing via GPO to prevent SMB Relay and Man-in-the-Middle attacks.

### 2. Detection & Analysis

- Determine if the source is a legitimate vulnerability scanner or an admin management tool.
- Check the Account\_Name. Is it a standard user, a service account, or an anonymous login?
- Identify if the shares being targeted contain sensitive info (e.g., \\PCD10\\SYSVOL, \\PCD10\\C\$).
- Look for Event ID 4624 (Logon) from the same source IP immediately preceding the scan.

### 3. Containment

- Block the Source IP (192.168.0.158) at the host firewall or the core switch.
- Run `net session` on the target server and terminate active connections from the attacker.
- Move the source workstation to a "Quarantine VLAN" for forensic investigation.

### 4. Eradication

- Remove any non-standard or "hidden" shares that are not required for business operations.
- Ensure the "Everyone" group is removed from share permissions; use "Authenticated Users" or specific groups.
- If a specific domain account was used, perform a mandatory password reset.

### 5. Recovery

- Verify that ABE is hiding unauthorized shares from standard user views.
- Monitor for Event ID 5142 (A network share was added) to catch any persistence attempts.
- Conduct an authorized internal scan to ensure no other open shares are exposed.

### 6. Lessons Learned & Reporting

- Analyze how the attacker bypassed internal segmentation to reach the file server segment.
- Update the "Data Handling Policy" to restrict who can create new network shares.
- Document the list of accessed shares and the sensitivity of the data exposed.

#### Success Metrics Table

| Metric                     | Target                                  |
|----------------------------|-----------------------------------------|
| Mean Time to Detect (MTTD) | <15 Minutes                             |
| Unnecessary Shares Removed | 100% of discovered non-compliant shares |
| Containment Time           | <20 Minutes                             |

#### Analysis Questions and Answers

**1. Why do attackers enumerate SMB shares?**

*Answer: To find sensitive data or weak permissions.*

**2. Detection methods?**

*Answer: Monitor for unusual SMB requests or failed access attempts.*

**3. Preventive measures?**

*Answer: Apply least privilege, audit share access, and monitor abnormal traffic.*

## Successful Root Elevation (Kali)

### Scenario

A standard user on a Linux system successfully escalated privileges to the root account using the su (substitute user) command. The activity originated from a known attacker platform (Kali Linux). This indicates that the attacker has surpassed the initial access phase and now possesses full administrative control over the target OS.

### Incident Classification

| Category          | Details                                               |
|-------------------|-------------------------------------------------------|
| Incident Type     | Privilege Escalation - Root Elevation                 |
| Severity          | CRITICAL                                              |
| Priority          | High (Total System Compromise)                        |
| Detection Sources | /var/log/auth.log (Debian) or /var/log/secure (RHEL)  |
| Timestamp         | 21:35:01                                              |
| Source IP         | 192.168.100.13 (Kali Linux)                           |
| Affected Host     | kali (Target Linux System)                            |
| MITRE ATT&CK      | T1548.003 (Abuse Elevation Control Mechanism)         |
| Tags              | Linux, Privilege Escalation, Kali Attack, su-root     |
| Recommendation    | Terminate session, lock user, and audit .bash_history |

### Alert Rule & Logic

Monitors for successful su attempts to the root account where the initiating user is not a pre-approved administrator (UID != 1000).

```
index=main "session opened for user root"
| rex field=_raw "by\s+(?<Admin_User>[^\s]+\s)(uid=(?<User_ID>\d+)\s)"
| search User_ID!=1000 AND NOT Admin_User IN ("authorized_manager", "service_acct", "root")
| table _time, host, Admin_User, User_ID
```

## Alert Settings & Dashboard

**Edit Alert** [X]

**Alert** Successful Root Elevation Detection (Linux)

**Description** Detects when a standard user successfully elevates to root. To reduce False Positives, we exclude authorized admins.

**Alert type** Scheduled | Real-time

Run on Cron Schedule ▾

**Time Range** All time ▸

**Cron Expression** \*/1 \* \* \* \*  
e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)

**Expires** 24 | hour(s) ▾

**Trigger Conditions**

**Trigger alert when** Number of Results ▾

is greater than ▾ 0

**Trigger** Once | For each result

**Throttle** ☐

**Trigger Actions**

+ Add Actions ▾

**When triggered** ▾

Add to Triggered Alerts Remove

Severity Critical ▾

Cancel Save

## Dashboard View

|                                          |                                             |        |           |          |
|------------------------------------------|---------------------------------------------|--------|-----------|----------|
| 2026-02-16 21:35:01 Jordan Standard Time | Successful Root Elevation Detection (Linux) | search | Scheduled | Critical |
|------------------------------------------|---------------------------------------------|--------|-----------|----------|

## Phases and Actions

### 1. Preparation

- Configure `/etc/pam.d/su` to require membership in the wheel group.
- Forward logs to a central SIEM to prevent attackers from wiping `/var/log/auth.log`.
- Set `PermitRootLogin no` in `/etc/ssh/sshd_config`.

### 2. Detection & Analysis

- Determine which standard user account was used to escalate (Check UID in logs).
- Review `.bash_history` for the user to see if they ran exploit scripts or used a stolen password.
- Run `debsums` or `rpm -V` to ensure `/bin/su` or `/usr/bin/sudo` haven't been replaced.
- Check for active TTY sessions or SSH connections from the Kali IP (192.168.100.13).

### 3. Containment

- Terminate the unauthorized root shell: `kill -9 -u root -t <tty_name>`
- Immediately lock the compromised user: `passwd -l <username>`
- Use iptables or nftables to drop all traffic from 192.168.100.13.

### 4. Eradication

- Change the root password and the passwords for all users in the sudo or wheel groups.
- Inspect `/root/.ssh/authorized_keys` for unauthorized public keys.
- Search `/etc/cron.*` and systemd units for malicious scripts installed during root access.

### 5. Recovery

- Disable the root password (`passwd -d root`) and force all admins to use sudo.
- Re-enable authorized accounts only after confirming credentials are not leaked.
- Install and configure auditd to log every command executed with root privileges.

### 6. Lessons Learned & Reporting

- Determine if the password was brute-forced or found in a "leaky" config file.
- Recommend implementing Sudo I/O logging to record full session keystrokes.
- Document the compromised account, the escalation method, and the IP of the Kali host.

#### Success Metrics Table

| Metric                     | Target                      |
|----------------------------|-----------------------------|
| Mean Time to Detect (MTTD) | <1 Minute                   |
| Time to Session Kill       | <10 Minutes                 |
| Root Password Rotation     | Immediate upon confirmation |

#### Analysis Questions and Answers

**1. How can root access be gained?**

*Answer: Exploiting sudo misconfigurations, kernel vulnerabilities, or SUID binaries.*

**2. Detection methods?**

*Answer: Monitor privileged command execution and log sudo attempts.*

**3. Mitigation?**

*Answer: Patch vulnerabilities and restrict sudo privileges.*

## Local Brute Force Detection (Kali)

### Scenario

The monitoring system has detected multiple failed authentication attempts on a local Linux host. The attack pattern indicates a manual or automated brute-force attempt targeting the root account. The activity suggests an adversary is attempting to guess credentials to escalate privileges or gain initial access.

### Incident Classification

| Category          | Details                                                   |
|-------------------|-----------------------------------------------------------|
| Incident Type     | Credential Access - Brute Force                           |
| Severity          | Medium                                                    |
| Priority          | High (Potential for Root Compromise)                      |
| Detection Sources | Linux Auth Logs (/var/log/auth.log), SIEM                 |
| Timestamp         | 22:33:01                                                  |
| Source IP         | 192.168.100.13                                            |
| Affected Host     | kali                                                      |
| MITRE ATT&CK      | T1110 (Brute Force)                                       |
| Tags              | Linux, Brute Force, SSH, Root                             |
| Recommendation    | Block IP, enforce account lockout, disable root SSH login |

### Alert Rule & Logic

Splunk-style query: extracts the "Real User" attempting the elevation and alerts if the failure count  $\geq$  5 within a specific timeframe.

```
index=main "authentication failure" "user=root"
| rex "ruser=(?<Real_User>\S+)"
| stats count as failure_count by Real_User, host
| where failure_count >= 5
| table _time, Real_User, host, failure_count
```

## Alert Settings & Dashboard

**Edit Alert** [X]

**Alert** Local Password Spraying/Brute Force (Linux)

**Description** Alerts only if there are more than 5 failed attempts within 2 minutes. This ignores occasional typos.

**Alert type** Scheduled Real-time

Run on Cron Schedule ▾

**Time Range** All time ▶

**Cron Expression** \*/3 \* \* \* \*  
e.g. 00 18 \*\*\* (every day at 6PM). [Learn More](#)

**Expires** 24 hour(s) ▾

**Trigger Conditions**

**Trigger alert when** Number of Results ▾

is greater than ▾ 0

**Trigger** Once For each result

**Throttle ?** ☐

**Trigger Actions**

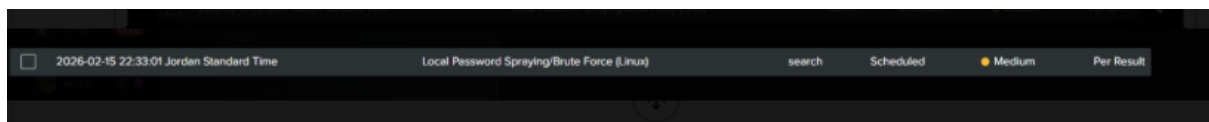
+ Add Actions ▾

**When triggered** ▾ Add to Triggered Alerts Remove

**Severity** Medium ▾

Cancel Save

## Dashboard View



## Phases and Actions

### 1. Preparation

- Disable direct root login in `/etc/ssh/sshd_config` (PermitRootLogin no).
- Install and configure Fail2Ban to monitor logs and auto-jail IPs.
- Implement pam\_faillock to lock accounts after X failed attempts.

### 2. Detection & Analysis

- Review `/var/log/auth.log` to see if any "Success" followed the "Failures".
- Confirm if 192.168.100.13 is an authorized tester or a rogue device.
- Determine if the attack is a "Password Spray" or "Brute Force".

### 3. Containment

- Manually block the source IP: `iptables -A INPUT -s 192.168.100.13 -j DROP`.
- Temporarily lock the `newuser` account if it is the launch point for su attempts.
- Disconnect the target host if an automated script is detected.

### 4. Eradication

- Change passwords for both `newuser` and `root` accounts immediately.
- Scan for brute-force tools (Hydra, Medusa) in `/tmp` or `/dev/shm`.

### 5. Recovery

- Watch for repeated failures from different IPs (distributed attack).
- Run `lastlog` to ensure no unauthorized logins were successful.
- Restart SSH services after applying hardening configurations.

### 6. Lessons Learned & Reporting

- Discuss using a "Jump Box" to prevent direct access to sensitive hosts.
- Update the SIEM to notify the On-Call Engineer via SMS for high-frequency failures.

#### Success Metrics Table

| Metric                     | Target                     |
|----------------------------|----------------------------|
| Mean Time to Detect (MTTD) | <2 Minutes                 |
| Containment Time           | <10 Minutes                |
| Root Account Safety        | 100% (no successful login) |

#### Analysis Questions and Answers

**1. Where are failed login attempts logged?**

*Answer: /var/log/auth.log or /var/log/secure.*

**2. Which tool can automatically block repeated failures?**

*Answer: Fail2Ban.*

**3. What is a secure alternative to passwords?**

*Answer: SSH key-based authentication.*



## Crontab Modification Detected (Kali)

### Scenario

The monitoring system detected a modification to the crontab via the crontab -e command. This alert was triggered by the execution of the crontab -e command. In a security context, unauthorized cronjob modifications are a primary method for attackers to maintain Persistence (T1053.003), allowing them to re-execute malicious code even after a system restart or session termination.

### Incident Classification

| Category          | Details                                             |
|-------------------|-----------------------------------------------------|
| Incident Type     | Persistence - Cronjob Modification                  |
| Severity          | Medium                                              |
| Priority          | High                                                |
| Detection Sources | Auditd, Syslog, Auth Log                            |
| Timestamp         | 22:15:09                                            |
| User Account      | kali                                                |
| Target File       | /var/spool/cron/crontabs/kali                       |
| Affected Host     | kali-linux-vm                                       |
| MITRE ATT&CK      | T1053.003 (Scheduled Task/Job: Cron)                |
| Tags              | Linux, Persistence, Cronjob, Kali                   |
| Recommendation    | Remove malicious cron entry and audit user activity |

### Alert Rule & Logic

Detects the modification of the crontab binary or direct writes to cron directories like /etc/cron.d/ or /var/spool/cron/.

```
index=main "crontab" "END EDIT"
| rex field=_raw "\((?<Crontab_User>[^\)]+)\) END EDIT"
| table _time, host, Crontab_User
```

## Alert Settings & Dashboard

**Edit Alert**

Alert: **Scheduled Task Persistence Detected (Linux)**

Description: This detection alerts when a user edits the crontab on a Linux system. Attackers can use cron jobs to run malicious commands automatically and keep persistence on the system.

Alert type: **Scheduled** | Real-time

Run on Cron Schedule ▾

Time Range: All time ▸

Cron Expression: \*/1 \* \* \* \*

e.g. 00 18 \*\*\* (every day at 6PM). [Learn More](#)

Expires: 24 | hour(s) ▾

**Trigger Conditions**

Trigger alert when: Number of Results ▾

is greater than ▾ 0

Trigger: **Once** | For each result

Throttle ? ☐

**Trigger Actions**

+ Add Actions ▾

When triggered ▾

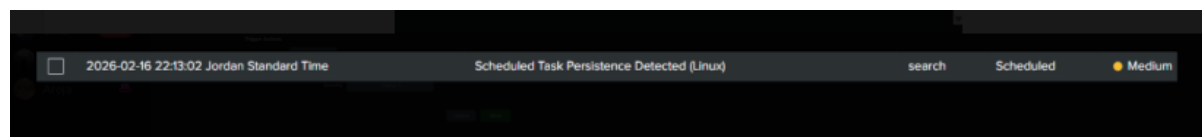
Add to Triggered Alerts

Severity: **Medium** ▾

[Remove](#)

Cancel Save

## Dashboard View



## Phases and Actions

### 1. Preparation

- Add rules to `/etc/audit/audit.rules` to monitor writes to `/var/spool/cron/`.
- Use `cron.allow` and `cron.deny` to restrict which users can create cron jobs.
- Ensure Linux logs are streamed to a SIEM to prevent local deletion of evidence.

### 2. Detection & Analysis

- List the current cron jobs for the user: `crontab -l -u kali`.
- Look for suspicious paths (e.g., `/tmp/`, `/dev/shm/`) or encoded commands (base64).
- Check the parent process of the `crontab` command (e.g., was it spawned by a shell or a python script?).

### 3. Containment

- Comment out or remove the suspicious line from the crontab file.
- If the cron job is currently running a script, kill the process ID (PID) immediately.
- If the cron job is a reverse shell, isolate the host from the network.

### 4. Eradication

- Clear the user's crontab entirely if it is fully compromised: `crontab -r -u kali`.
- Remove any scripts or binaries referenced in the malicious cron job.
- Check for other persistence methods like `.bashrc` or `systemd` services.

### 5. Recovery

- Ensure only root can write to `/etc/cron.d/` and related system directories.
- Verify that `auditd` is correctly logging any future attempts to modify cron files.
- Use AIDE or Tripwire to verify the integrity of the filesystem.

### 6. Lessons Learned & Reporting

- Determine how the attacker gained access to the kali account to run crontab.
- Recommend using SELinux or AppArmor to further restrict cron execution.
- Document the malicious command string and the frequency of the job.

#### Success Metrics Table

| Metric                      | Target                              |
|-----------------------------|-------------------------------------|
| Mean Time to Detect (MTTD)  | <2 Minutes                          |
| Mean Time to Contain (MTTC) | <10 Minutes                         |
| Unauthorized Executions     | 0 (Job neutralized before next run) |

#### Analysis Questions and Answers

**1. What is the Linux equivalent of Windows scheduled tasks?**

*Answer: Cron jobs in `/etc/crontab` or user's crontab.*

**2. How to list all cron jobs for a user?**

*Answer: `crontab -l -u [username]`.*

**3. Which cron jobs indicate suspicious activity?**

*Answer: Jobs executing scripts from `/tmp` or downloading external files.*

## Critical File Modification (Kali)

### Scenario

A critical security alert was triggered on the kali-linux-target host after an unauthorized modification was detected in the /etc/passwd file. The simulation involved appending a new root-level user directly to the file. This technique is a high-confidence indicator of Data Manipulation (T1565.001), aimed at creating a permanent backdoor by adding a new user with a User ID (UID) of 0.

### Incident Classification

| Category          | Details                                                        |
|-------------------|----------------------------------------------------------------|
| Incident Type     | Impact / Persistence - System File Manipulation                |
| Severity          | CRITICAL                                                       |
| Priority          | High                                                           |
| Detection Sources | Audit, File Integrity Monitor (FIM), Syslog                    |
| Timestamp         | 09:12:45                                                       |
| User Account      | kali                                                           |
| Modified File     | /etc/passwd                                                    |
| MITRE ATT&CK      | T1565.001 (Stored Data Manipulation)                           |
| Affected Host     | kali-linux-target                                              |
| Recommendation    | Audit file for new UID 0 users and compare with clean back-ups |

### Alert Rule & Logic

Detects SYSCALL events (open, write, rename) targeting sensitive paths like /etc/passwd, /etc/shadow, or /etc/sudoers.

```
index=main (sourcetype=linux_audit OR "sudo:") ("/etc/passwd" OR "/etc/shadow" OR "/etc/sudoers")
| rex field=_raw "USER=(?<User>\S+)"
| rex field=_raw "COMMAND=(?<Command>.*)"
| eval Targeted_File=case(
    like(_raw, "%/etc/passwd%"), "/etc/passwd",
    like(_raw, "%/etc/shadow%"), "/etc/shadow",
    like(_raw, "%/etc/sudoers%"), "/etc/sudoers",
    1=1, "Other")
| table _time, host, User, Command, Targeted_File, _raw
```

## Alert Settings & Dashboard

**Edit Alert** [X]

Alert: **Critical Configuration File Modification (Linux)**

Description: This detection alerts when critical system files such as /etc/passwd, /etc/shadow, or /etc/sudoers are access. Attackers may change these files to create new accounts, [icon]

Alert type: **Scheduled** | Real-time

Run on Cron Schedule ▾

Time Range: All time ▸

Cron Expression: \*/1 \* \* \* \*  
e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)

Expires: 24 | hour(s) ▾

**Trigger Conditions**

Trigger alert when: Number of Results ▾

is greater than ▾ 0

Trigger: **Once** | For each result

Throttle ? ☐

**Trigger Actions**

+ Add Actions ▾

When triggered ▾

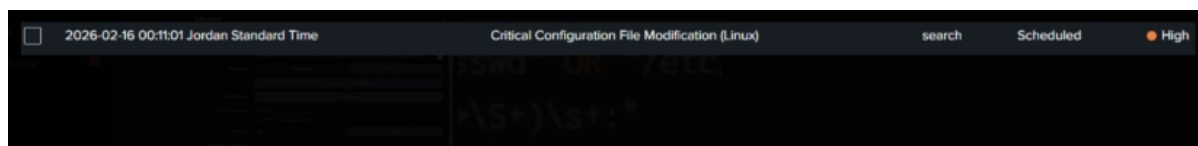
Add to Triggered Alerts

Severity: High ▾

Remove

Cancel Save

## Dashboard View



## Phases and Actions

### 1. Preparation

- Ensure rules like `-w /etc/passwd -p wa -k identity` are active in `audit.rules`.
- Establish a known-good cryptographic hash (SHA-256) for all critical system files.
- Maintain offline, read-only backups of `/etc/` configuration files for comparison.

### 2. Detection & Analysis

- Use `diff` to compare the current `/etc/passwd` with a known clean backup.
- Use `ausearch -i -k identity` to find the real user who initiated the change.
- Identify the Parent Process ID (PPID); check if it originated from a web server or an SSH session.
- Check `/etc/shadow` for any password hash changes occurring at the same timestamp.

### 3. Containment

- Disconnect the target from the network; an attacker with file-write access on `/etc/passwd` is a "Total Compromise."
- Disable any newly created accounts (e.g., `hacker`) using `passwd -l hacker`.
- Terminate any active shells associated with the user who performed the modification.

### 4. Eradication

- Revert the file to its original state using a verified backup or by manually removing malicious lines.
- Check `/usr/bin/ssh`, `/bin/ls`, and `/bin/ps` for unauthorized checksum changes (Rootkit check).
- Audit `/root/.ssh/authorized_keys` for unauthorized public keys added by the attacker.

### 5. Recovery

- Because of the severity, a full OS re-install from a trusted image is highly recommended.
- Ensure all users with sudo access are forced to use Multi-Factor Authentication.
- Place the affected host on a "High-Risk" monitoring list for 30 days.

### 6. Lessons Learned & Reporting

- How did the kali user obtain the permissions to write to a root-owned file?
- Implement immutable file attributes (`chattr +i`) for critical files where possible.
- Document the added user string and the attack vector (e.g., misconfigured sudo permissions).

#### Success Metrics Table

| Metric                      | Target                          |
|-----------------------------|---------------------------------|
| Mean Time to Detect (MTTD)  | <30 Seconds (Real-time FIM)     |
| Mean Time to Contain (MTTC) | <15 Minutes                     |
| Root Access Duration        | <10 Minutes from incident start |

#### Analysis Questions and Answers

**1. Which files are critical to monitor?**

*Answer: /etc/passwd, /etc/shadow, /var/log/auth.log.*

**2. How can modifications be detected?**

*Answer: Use file integrity monitoring tools like Tripwire or AIDE.*

**3. Immediate action upon detection?**

*Answer: Isolate system, investigate attacker activity, restore files from backup.*

## Remote SSH Access (Kali)

### Scenario

The SIEM has detected a successful remote interactive login to the Kali Linux host originating from a Windows-based machine (192.168.100.15). The connection was established via SSH on Port 22 using a password for the account kali. This activity may represent an attacker moving laterally from a compromised Windows workstation to a Linux-based attack or management platform.

### Incident Classification

| Category              | Details                                                 |
|-----------------------|---------------------------------------------------------|
| Incident Type         | Lateral Movement - Remote SSH Access                    |
| Severity              | Critical                                                |
| Priority              | High                                                    |
| Detection Sources     | Auth.log / Secure Log, Syslog, Network Netflow          |
| Timestamp             | 23:45:12                                                |
| Source IP (Windows)   | 192.168.100.15                                          |
| Destination IP (Kali) | 192.168.100.20                                          |
| MITRE ATT&CK          | T1021.004 (Remote Services: SSH)                        |
| Tags                  | Linux, SSH, Remote Access, Windows-Source               |
| Recommendation        | Verify authorization and restrict Port 22 to Jump Boxes |

### Alert Rule & Logic

Triggers when the SSH daemon (sshd) logs an "Accepted password" or "Accepted publickey" message where the source IP belongs to a Windows subnet or specific workstation.

```
index=main sourcetype=syslog sshd "Accepted password"
| rex field=_raw "Accepted password for (?<User>\S+) from (?<Source_IP>\d+\.\d+\.\d+\.\d+) port"
| search NOT User IN ("authorized_manager", "service_acct", "root")
| table _time, host, User, Source_IP
```

## Alert Settings & Dashboard

**Edit Alert**

Alert: **Successful SSH Login from Remote Source (Linux)**

Description: This alert triggers when a successful SSH login is detected for a non-administrative user account. It captures the target username and the source IP address from which

Alert type: **Scheduled** | Real-time

Run on Cron Schedule ▾

Time Range: All time ▾

Cron Expression: \*/1 \* \* \* \*

e.g. 00 18 \* \* \* (every day at 6PM). [Learn More](#)

Expires: 24 | hour(s) ▾

**Trigger Conditions**

Trigger alert when: Number of Results ▾

is greater than ▾ 0

Trigger: **Once** | For each result

Throttle ? ☐

**Trigger Actions**

+ Add Actions ▾

When triggered ▾

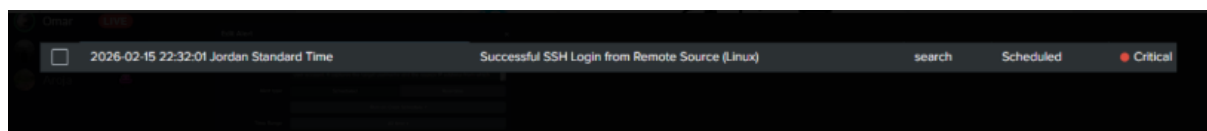
Add to Triggered Alerts

Severity: **Critical** ▾

Remove

Cancel Save

## Dashboard View



## Phases and Actions

### 1. Preparation

- Disable password-based authentication; enforce SSH Key-based auth only.
- Restrict Port 22 access to specific IT Management VLANs or "Jump Boxes".
- Ensure LogLevel VERBOSE is set in /etc/ssh/sshd\_config to capture fingerprint details.

### 2. Detection & Analysis

- Verify if the Windows user (e.g., an administrator) is authorized for remote Kali access.
- Inspect /var/log/auth.log on the Kali host for the full session duration and metadata.
- Ensure the internal Source IP (192.168.100.15) belongs to a trusted management segment.



### 3. Containment

- Immediately terminate the active SSH session using `pkill -u kali` or `kill <PID>`.
- Temporarily block the Windows Source IP at the Kali host firewall (iptables / ufw).
- If unauthorized, disable the kali user account or change the password immediately.

### 4. Eradication

- Review `/.ssh/authorized_keys` for any newly added or unrecognized public keys.
- Look for uploaded scripts or tools transferred from the Windows host during the session.
- Verify `/etc/ssh/sshd_config` was not modified to allow unauthorized access methods.

### 5. Recovery

- Force a password/key rotation for all accounts that have SSH access to the Kali machine.
- Restore access only after enforcing Multi-Factor Authentication (MFA) or Jump Box requirements.
- Set high-priority alerts for any subsequent SSH attempts from the 192.168.100.0/24 subnet.

### 6. Lessons Learned & Reporting

- Determine if the Windows workstation was compromised, leading to this lateral movement.
- Update the "Remote Access Policy" to strictly prohibit workstation-to-server SSH traffic.
- Document the session start/end times, the source Windows machine, and any commands executed.

#### Success Metrics Table

| Metric                        | Target      |
|-------------------------------|-------------|
| Mean Time to Detect (MTTD)    | <2 Minutes  |
| Unauthorized Session Duration | <10 Minutes |

#### Analysis Questions and Answers

**1. Where are SSH logins recorded?**

*Answer: /var/log/auth.log or /var/log/secure.*

**2. How to detect unauthorized SSH access?**

*Answer: Monitor unusual source IPs, repeated login attempts, or logins outside normal hours.*

**3. Mitigation measures?**

*Answer: Disable root login, enforce key-based authentication, and block suspicious IPs.*

## Firewall Defense Evasion Attempt (Kali)

### Scenario

The SIEM detected a critical change in the host's security posture on kali-linux-vm. The user kali executed a command to disable the firewall service (ufw disable). This activity is a hallmark of the "Impair Defenses" tactic, where an adversary neutralizes local security controls to facilitate lateral movement or external communication without being blocked or logged by the network shim.

### Incident Classification

| Category          | Details                                               |
|-------------------|-------------------------------------------------------|
| Incident Type     | Defense Evasion - Impair Defenses                     |
| Severity          | Critical                                              |
| Priority          | High                                                  |
| Detection Sources | Syslog, systemd, Auditd, Command History              |
| Timestamp         | 11:30:15                                              |
| User Account      | kali                                                  |
| Action            | Service Stop / Rule Flush                             |
| Affected Host     | kali-linux-vm                                         |
| MITRE ATT&CK      | T1562.004 (Disable or Modify System Firewall)         |
| Tags              | Linux, Firewall, UFW, Evasion                         |
| Recommendation    | Re-enable firewall immediately and investigate source |

### Alert Rule & Logic

Monitors for the execution of firewall management binaries (ufw, iptables, nft) combined with high-risk keywords like disable, stop, or -F (flush).

```
index=linux host="kali" source="/var/log/auth.log" "ufw disable"
| rex field=_raw "USER=(?<admin_user>\w+)"
| rex field=_raw "COMMAND=(?<executed_command>.+)"
| eval severity="Critical"
| table _time, admin_user, executed_command, severity, host
| rename _time as "Event Time", admin_user as "Admin User", executed_command as "Command", severity as "Severity", host as "Host"
```

7 events (before 2/21/26 7:29:41.000 PM) No Event Sampling Job 13

## Alert Settings & Dashboard

## Dashboard View



## Phases and Actions

### 1. Preparation

- Ensure Audit is configured to track all executions of `/sbin/iptables` and `/usr/sbin/ufw`.
- Implement remote syslog forwarding so logs cannot be tampered with locally.
- Require all legitimate firewall changes to be correlated with a Change Management ticket.

### 2. Detection & Analysis

- Run `sudo ufw status` or `sudo iptables -L -n` to identify unauthorized "ALLOW" rules.
- Identify if the command was executed via a local terminal, a remote SSH session, or an automated script.
- Check if the action matches a scheduled maintenance window or troubleshooting ticket.

### 3. Containment

- Immediately re-enable the firewall: `sudo ufw enable`.
- If the command came from a remote session, terminate that session and block the source IP.
- If part of a larger compromise, take a forensic snapshot of the VM's memory and disk.

#### 4. Eradication

- Restore the firewall configuration from a known-good backup file (e.g., /etc/ufw/user.rules).
- Investigate how the user obtained the sudo privileges required to disable the firewall.
- Check for cronjobs or scripts that might try to disable the firewall again on reboot.

#### 5. Recovery

- Confirm that the firewall service is set to "Enabled" and "Active" across reboots.
- Re-run a vulnerability scan to ensure no new ports were left open during the "Down" period.
- Place the host on a strict monitoring list for any privileged command execution.

#### 6. Lessons Learned & Reporting

- Recommend restricting firewall management permissions to a specific "Security Admin" group.
- Document the duration the firewall was down and any traffic that bypassed the security stack.

#### Success Metrics Table

| Metric                        | Target                                  |
|-------------------------------|-----------------------------------------|
| Mean Time to Detect (MTTD)    | <1 Minute                               |
| Mean Time to Remediate (MTTR) | <5 Minutes (Re-enabling service)        |
| Unauthorized Rule Presence    | 0 (All rules verified against baseline) |

#### Analysis Questions and Answers

**1. What techniques are used to bypass firewalls?**

*Answer: Port hopping, protocol tunneling, or ICMP/UDP encapsulation.*

**2. How can evasion attempts be detected?**

*Answer: Analyze firewall logs for unusual patterns or non-standard ports.*

**3. Mitigation?**

*Answer: Enforce strict firewall rules and inspect suspicious outbound traffic.*

## SUID Privilege Escalation Discovery (Kali)

### Scenario

The SIEM detected a standard user (kali) performing aggressive enumeration of the filesystem to identify files with the SUID bit set. Specifically, the user executed a find command filtered for permission bit 4000. This is a classic reconnaissance step used to identify "Living off the Land" binaries that can be exploited to spawn a root shell (referencing GTFOBins techniques).

### Incident Classification

| Category          | Details                                                   |
|-------------------|-----------------------------------------------------------|
| Incident Type     | Discovery / Privilege Escalation - SUID Enumeration       |
| Severity          | High                                                      |
| Priority          | High                                                      |
| Detection Sources | Auditd, Process Monitoring                                |
| Timestamp         | 19:58:56                                                  |
| User Account      | kali                                                      |
| Command           | <code>find / -perm -4000 2&gt;/dev/null</code>            |
| MITRE ATT&CK      | T1083 (File and Directory Discovery)                      |
| Tags              | Linux, SUID, Privilege Escalation, Enumeration            |
| Recommendation    | Remove unnecessary SUID bits and monitor for exploitation |

### Alert Rule & Logic

Detects process execution events where the command line contains the specific permission filter "-perm -4000" or "-perm /4000", which are unique to SUID discovery.

The screenshot shows a SIEM interface with an alert rule configuration at the top and a list of detected events below.

**Alert Rule Configuration:**

```
index=linux "privileged_find" NOT (comen"ip" OR comen"cut" OR comen"head" OR comen"grep" OR comen"dash" OR comen"tail")
| rex field=_raw "exe=\"(?<tool>[^\"]+)"
| rex field=_raw "comen=\"(?<command_name>[^\"]+)"
| eval severity="High", attack_type="Privilege Escalation", technique="SUID Enumeration"
| table _time, command_name, tool, technique, severity, host
| rename command_name as "Executed_Command", tool as "Tool_Path", technique as "Technique", severity as "Severity"
```

**Event List:**

| Time                    | Executed_Command | Tool_Path | Technique        | Severity | Host |
|-------------------------|------------------|-----------|------------------|----------|------|
| 2026-02-21 19:58:51.316 |                  |           | SUID Enumeration | High     | kali |
| 2026-02-28 22:29:48.889 |                  |           | SUID Enumeration | High     | kali |
| 2026-02-28 22:26:38.354 |                  |           | SUID Enumeration | High     | kali |

## Alert Settings & Dashboard

**Edit Alert** [Close]

**Settings**

Alert: **PRV\_01\_SUID\_Scan\_Detected**

Description: Systematic file system scanning for SUID permissions detected. This activity is a strong indicator of an internal reconnaissance phase aimed at Privilege Escalation (MITRE ATT&CK T1548.001). Attackers exploit these misconfigured binaries to gain unauthorized Root access. An immediate forensic investigation is required to mitigate potential system compromise.

Alert type: **Scheduled** | Real-time

Expires: **24** | hour(s) ▾

**Trigger Conditions**

Trigger alert when: **Per-Result ▾**

Throttle <sup>?</sup> ☐

**Trigger Actions**

+ Add Actions ▾

When triggered ▾

- Add to Triggered Alerts Remove
- Severity: **High ▾**

Cancel Save

## Dashboard View



## Phases and Actions

### 1. Preparation

- Generate a master list of authorized SUID binaries: `find / -perm -4000 > baseline.txt`.
- Check existing SUID binaries against GTFOBins to identify "dangerous" files.
- Ensure Audit is logging `execve` system calls to track UID transitions.

### 2. Detection & Analysis

- Confirm the binary used for discovery (e.g., `find`, `locate`, or custom scripts).
- Check if any of the discovered SUID binaries are non-standard or recently modified.
- Look for subsequent commands using `-exec` (for `find`) or `:py` (for `vim`) to trigger shells.

### 3. Containment

- Immediately remove the SUID bit from non-essential binaries: `chmod u-s /path/to/binary`.
- Terminate the user's shell session to stop the exploitation attempt.

- If a root shell was successfully spawned, isolate the host for forensic imaging.

#### 4. Eradication

- Delete any malicious binaries the attacker may have compiled and marked as SUID (e.g., a custom rootshell binary).
- Use rkhunter or chkrootkit to ensure no persistent backdoors were installed.
- Rotate the root password and all sudo-capable user passwords.

#### 5. Recovery

- Apply configuration management (Ansible/Puppet) to ensure SUID bits remain disabled on specified binaries.
- Use debsums (Debian) or rpm -V (RHEL) to verify the integrity of system binaries.
- Continue monitoring for failed sudo or su attempts for the next 7 days.

#### 6. Lessons Learned & Reporting

- Determine if the SUID bit was left by a lazy install script or a previous administrator.
- Enforce a "No-SUID" policy for binaries that have known GTFOBins exploitation paths.
- Document the specific discovery command used and the risk it posed to the domain.

#### Success Metrics Table

| Metric                     | Target                                   |
|----------------------------|------------------------------------------|
| Mean Time to Detect (MTTD) | <2 Minutes                               |
| Dangerous SUIDs Removed    | 100% of discovered non-standard binaries |
| Root Compromise Success    | 0% (Attack stopped at Discovery phase)   |

#### Analysis Questions and Answers

**1. What are SUID binaries?**

*Answer: Executables with Set-UID bit set that run with file owner privileges.*

**2. How are SUID abuses detected?**

*Answer: Regularly list all SUID binaries and monitor unauthorized changes.*

**3. Remediation?**

*Answer: Remove unnecessary SUID bits and restrict access.*

## Symbolic Link Hijacking (Kali)

### Scenario

A low-privileged user (app\_user) created a symbolic link in the world-writable /tmp directory. The link, named log\_file, was pointed toward the sensitive system file /etc/passwd. A high-privileged process (PID 1245) running as Root followed this link, potentially resulting in an unauthorized modification of a system configuration file. This is often indicative of a TOCTOU (Time-of-Check to Time-of-Use) race condition attack.

### Incident Classification

| Category          | Details                                                 |
|-------------------|---------------------------------------------------------|
| Incident Type     | Privilege Escalation - Symlink Hijacking                |
| Severity          | High / Critical                                         |
| Priority          | High                                                    |
| Detection Sources | Audit (Linux), Sysmon (Windows), Kernel Logs            |
| Timestamp         | 14:02:55                                                |
| User Account      | app_user                                                |
| Target File       | /etc/passwd                                             |
| MITRE ATT&CK      | T1574 (Hijack Execution Flow)                           |
| Tags              | Linux, Symlink, TOCTOU, Privilege Escalation            |
| Recommendation    | Remove malicious symlink and enforce protected symlinks |

### Alert Rule & Logic

Monitors the symlink and linkat system calls specifically within world-writable directories like /tmp or /var/tmp.

index=linux "symlink\_creation" OR "ln -s"  
 | eval attack\_type="Symbolic Link Attack", severity="high"  
 | table \_time, host, user, command, attack\_type, severity  
 | rename user as "User", command as "Detected\_Command", attack\_type as "Attack\_Type", severity as "Severity"

6 events (before 2/2/26 8:08:49.000 PM) No Event Sampling

Events Patterns Statistics (6) Visualization

Show 20 Per Page Format Preview On

| _Time                   | host | User | Detected_Command             | Attack_Type          | Severity |
|-------------------------|------|------|------------------------------|----------------------|----------|
| 2026-02-21 20:46:31.807 | kali | root | /usr/sbin/sudoedit -e always | Symbolic Link Attack | High     |
| 2026-02-26 22:02:52.601 | kali | root | /usr/bin/x                   | Symbolic Link Attack | High     |
| 2026-02-26 22:06:13.126 | kali | root | /usr/bin/x                   | Symbolic Link Attack | High     |
| 2026-02-26 22:46:23.963 | kali | root | /usr/sbin/sshsearch          | Symbolic Link Attack | High     |



## Alert Settings & Dashboard

**Edit Alert**

**Settings**

Alert: **PRV\_04\_Symlink\_Creation\_Activity**

Description: Security alert for detecting attempts to create symbolic links. Monitoring rules (Auditd) have been verified as active through administrative commands captured in Splunk logs. This activity indicates potential file redirection or Privilege Escalation attempts, aligning with the MITRE ATT&CK technique T1557.

Alert type: **Scheduled** | Real-time

Expires: **24** | hour(s) ▾

**Trigger Conditions**

Trigger alert when: **Per-Result** ▾

Throttle: ☐

**Trigger Actions**

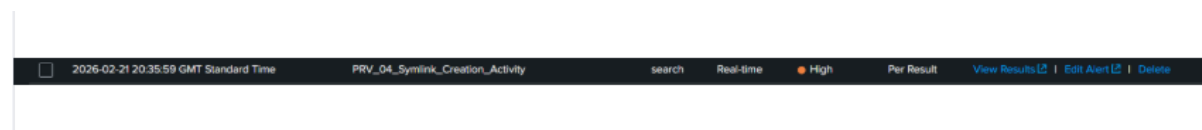
+ Add Actions ▾

When triggered: ▾

- Add to Triggered Alerts (Remove)
- Severity: **High** ▾

Cancel Save

## Dashboard View



## Phases and Actions

### 1. Preparation

- Enable `fs.protected_symlinks = 1` and `fs.protected_hardlinks = 1` in `sysctl`.
- Ensure File Integrity Monitoring is active for `/etc/passwd` and `/etc/shadow`.
- Ensure applications use `O_NOFOLLOW` when opening files in public directories.

### 2. Detection & Analysis

- Verify if the program checked file existence/permissions before the link was created.
- Analyze the high-privileged process (PID 1245) to see if it successfully modified the target.
- Review the session of `app_user` to identify how they determined the target log path.

### 3. Containment

- Immediately remove the malicious symbolic link from `/tmp`.
- Suspend the high-privileged process if it continues to interact with user-controlled paths.
- Restrict the `app_user` account's ability to create new links in temporary directories.

#### 4. Eradication

- Compare `/etc/passwd` or `/etc/shadow` against a clean backup for unauthorized changes.
- Move application log files out of world-writable directories like `/tmp`.
- Restrict write access to sensitive temporary directories.

#### 5. Recovery

- Apply system-wide symlink protection settings permanently via `/etc/sysctl.conf`.
- Update application code to use safer file-opening flags that do not follow symlinks.
- Watch for repeated symlink attempts from the same UID across different hosts.

#### 6. Lessons Learned & Reporting

- Determine why a high-privileged service was writing to a world-writable path.
- Document the vulnerability found in the service and the remediation steps taken.

#### Success Metrics Table

| Metric                     | Target                            |
|----------------------------|-----------------------------------|
| Mean Time to Detect (MTTD) | <1 Minute                         |
| Kernel Protection Status   | 100% (Protected Symlinks Enabled) |
| File Overwrite Success     | 0% (Attack thwarted before write) |

#### Analysis Questions and Answers

**1. What is symlink hijacking?**

*Answer: Creating malicious symbolic links to overwrite or access sensitive files.*

**2. Detection method?**

*Answer: Monitor for unexpected symlinks in critical directories.*

**3. Mitigation?**

*Answer: Restrict file creation permissions and validate symlinks.*

## Unauthorized Network Promiscuous Mode (Kali)

### Scenario

The SIEM has detected that the network interface eth0 on kali-linux-workstation has entered Promiscuous Mode. This change was logged by the kernel and correlated with activity from the user kali. Unless associated with an authorized network audit, this is a critical indicator of an adversary attempting to intercept local network traffic.

### Incident Classification

| Category           | Details                                                           |
|--------------------|-------------------------------------------------------------------|
| Incident Type      | Discovery / Credential Access - Network Sniffing                  |
| Severity           | High                                                              |
| Priority           | High                                                              |
| Detection Sources  | Kernel Logs (dmesg, kern.log), Auditd, Syslog                     |
| Timestamp          | 02:10:44                                                          |
| User Account       | kali                                                              |
| Affected Interface | eth0                                                              |
| MITRE ATT&CK       | T1040 (Network Sniffing)                                          |
| Tags               | Linux, Sniffing, Promiscuous, Kali                                |
| Recommendation     | Disable promiscuous mode, kill sniffing process, and isolate host |

### Alert Rule & Logic

Monitors kernel ring buffer and syslog for the specific string "entered promiscuous mode". Additionally, Auditd is used to track ioctl system calls that modify interface flags (SIOCSIFFLAGS).

```
index=main sourcetype=syslog process=kernel "promiscuous mode"
| table _time, host, process, _raw
```

## Alert Settings & Dashboard

The screenshot shows the 'Edit Alert' configuration window. It includes a close button (X) in the top right corner. The 'Settings' section contains the following fields:

- Alert:** Unauthorized Network Promiscuous Mode Detected (Linux)
- Description:** This alert triggers when a network interface (e.g., eth0) is manually switched into Promiscuous Mode, as recorded by the system kernel.
- Alert type:** Scheduled (selected) / Real-time
- Expires:** 24 / hour(s) ▼

The **Trigger Conditions** section includes:

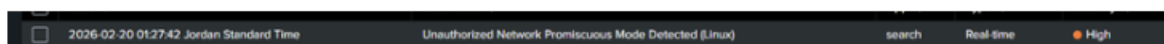
- Trigger alert when:** Per-Result ▼
- Throttle ?** ☐

The **Trigger Actions** section includes:

- + Add Actions ▼**
- When triggered:**
  - ▼
  - ⚠ Add to Triggered Alerts (with a Remove link)
  - Severity: High ▼

At the bottom right are 'Cancel' and 'Save' buttons.

## Dashboard View



## Phases and Actions

### 1. Preparation

- Ensure Audit is monitoring network configuration changes via `ioctl`.
- Create a list of authorized users and times for network diagnostic tools (e.g., Wireshark).
- Implement Port Security or 802.1X on switches to prevent unauthorized devices from joining segments.

### 2. Detection & Analysis

- Use `netstat -lnp` or `ss -p` to find the specific Process ID (PID) using the raw socket.
- Cross-reference the timestamp with authorized network troubleshooting tickets.
- Check for active instances of `tcpdump`, `wireshark`, `tshark`, or `bettercap`.

### 3. Containment

- Immediately disable promiscuous mode: `sudo ip link set eth0 promisc off`.
- Terminate the process identified in the Analysis phase: `sudo kill -9 [PID]`.
- If the sniffing activity is confirmed as malicious, isolate the host to prevent data from being exfiltrated.

#### 4. Eradication

- Check for unauthorized sniffing binaries in /tmp, /usr/local/bin, or hidden directories.
- Determine if any cleartext protocols (FTP, Telnet, HTTP) were active during the sniffing window.
- Investigate how the user obtained the root privileges required to alter interface flags.

#### 5. Recovery

- Move sensitive services from cleartext to encrypted protocols (e.g., FTP to SFTP, HTTP to HTTPS).
- Re-verify that all interfaces on the host are in a normal, non-promiscuous state.
- Set up real-time desktop notifications for administrators when interfaces change state.

#### 6. Lessons Learned & Reporting

- Evaluate if the network segment should be further VLAN-isolated to reduce the "sniffing blast radius."
- Document the duration of the sniffing and provide a list of potentially compromised cleartext sessions.

#### Success Metrics Table

| Metric                      | Target                                          |
|-----------------------------|-------------------------------------------------|
| Mean Time to Detect (MTTD)  | <1 Minute (Real-time Kernel Alert)              |
| Mean Time to Contain (MTTC) | <5 Minutes                                      |
| Data Breach Prevention      | 100% (If contained before session interception) |

#### Analysis Questions and Answers

**1. What is promiscuous mode?**

*Answer: Network interface captures all packets on the segment, not just its own.*

**2. Why is it dangerous?**

*Answer: Can be used to sniff sensitive network traffic.*

**3. Detection?**

*Answer: Use 'ip link' or monitoring tools to detect interfaces in promiscuous mode.*

## Hostname Spoofing/Change Detected (Kali)

### Scenario

The SIEM has detected a manual hostname change on the host kali-linux-workstation. The user kali used the hostnamectl utility to rename the system to Finance-PC-04. This activity is a common indicator of an attacker attempting to "hide in plain sight" by masquerading as a legitimate corporate asset, such as a finance department workstation or a network printer.

### Incident Classification

| Category          | Details                                      |
|-------------------|----------------------------------------------|
| Incident Type     | Defense Evasion / Masquerading               |
| Severity          | Medium                                       |
| Priority          | High (Potential for Active Network Recon)    |
| Detection Sources | Auditd, Syslog (systemd-hostnamed), Auth.log |
| Timestamp         | 13:40:05                                     |
| Old Hostname      | kali-linux-workstation                       |
| New Hostname      | Finance-PC-04                                |
| MITRE ATT&CK      | T1036 (Masquerading)                         |
| Tags              | Linux, Hostname, Spoofing, Identity          |
| Recommendation    | Revert hostname and investigate intent       |

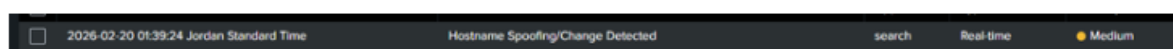
### Alert Rule & Logic

Monitors for the sethostname system call via Auditd and property changes logged by systemd-hostnamed. It also flags writes to /etc/hostname and /etc/hosts.

```
index=main sourcetype=syslog (process="systemd-hostnamed" OR "hostnamectl")  
| table _time, host, process, _raw
```

## Alert Settings & Dashboard

## Dashboard View



## Phases and Actions

### 1. Preparation

- Maintain an asset inventory linking MAC addresses/IPs to static hostnames.
- Ensure rules are set to watch `/etc/hostname` for write/attribute changes.
- Monitor DHCP logs for "Client Identifier" mismatches between IP and Hostname.

### 2. Detection & Analysis

- Check `auth.log` to see if the change was preceded by a `sudo` or `su` command.
- Use `hostnamectl status` to see if the change is Static, Transient, or Pretty.
- Determine if the host is performing scans or other malicious activities under the new name.

### 3. Containment

- Restore the original hostname: `sudo hostnamectl set-hostname kali-linux-workstation.`
- If the host is performing scans as "Finance-PC-04," isolate it at the switch level.
- Terminate any active SSH or local sessions for the user who performed the change.

#### 4. Eradication

- Inspect `/etc/hosts` for unauthorized entries that redirect traffic to malicious IPs.
- Check for newly generated SSL/TLS certificates that match the spoofed hostname.
- Look for scripts used to automate identity changes during system startup.

#### 5. Recovery

- Flush local and network DNS caches to ensure the correct name-to-IP mapping is restored.
- Re-verify the credentials of the user who performed the change.
- Ensure no cloud-init or nmcli scripts were modified to re-apply the spoofed name.

#### 6. Lessons Learned & Reporting

- Determine the intent behind the masquerade (e.g., to blend in with finance department traffic).
- Update hostname change monitoring to alert on any changes outside of approved maintenance windows.

#### Success Metrics Table

| Metric                      | Target              |
|-----------------------------|---------------------|
| Mean Time to Detect (MTTD)  | <2 Minutes          |
| Revert Time                 | <5 Minutes          |
| Unauthorized Reconnaissance | Stopped immediately |

#### Analysis Questions and Answers

**1. Why spoof hostnames?**

*Answer: To evade monitoring or impersonate trusted machines.*

**2. How is it detected?**

*Answer: Compare current hostname with baseline inventory and logs.*

**3. Mitigation?**

*Answer: Enforce hostname policies and monitor changes.*



## SQL Injection Attempt (Web)

### Scenario

The SIEM has triggered a Critical severity alert for a potential SQL Injection (SQLi) attack on a web application (DVWA). The attacker manipulated the User ID parameter in a GET request by injecting a single quote (') followed by common SQL logic (OR 1=1) to bypass authentication or extract database information.

### Incident Classification

| Category          | Details                                                   |
|-------------------|-----------------------------------------------------------|
| Incident Type     | Injection - SQL Injection                                 |
| Severity          | Critical                                                  |
| Priority          | High                                                      |
| Detection Sources | Web Server Logs (access.log), WAF                         |
| Timestamp         | 23:17:59                                                  |
| Source IP         | 172.17.0.1                                                |
| Target URI        | /vulnerabilities/sqli/?id=1' OR '1'='1                    |
| MITRE ATT&CK      | T1190 (Exploit Public-Facing Application)                 |
| Tags              | Web, SQLi, DVWA, Critical                                 |
| Recommendation    | Block IP, patch vulnerable parameter, implement WAF rules |

### Alert Rule & Logic

Monitors HTTP GET requests specifically for database manipulation patterns. It uses urldecode to expose obfuscated payloads and regex matching to identify common SQLi strings within active request parameters.

```
index="main" source="/tmp/dvwa_logs/access.log"
| eval decoded_payload = urldecode(_raw)
| where (match(decoded_payload, "GET\s+[/^?\s]+\?id=") AND match(decoded_payload, "(?i)(UNION\s+SELECT|OR\s+\d+=\d+|'\s+OR\s+'|--|#)"))
| eval Attack_Type="Confirmed SQLi Attempt", Severity="Critical"
| table _time, clientip, Attack_Type, Severity, decoded_payload
```

Alert Settings & Dashboard

Edit Alert

Settings

Alert

SQL Injection Attack Patterns Detected

Description

"This alert is designed to identify SQL Injection attempts by monitoring HTTP GET requests for specific database manipulation patterns such as UNION SELECT, OR 1=1, ..."

Search

```
index="main" source="/tmp/dvwa_logs/access.log"
| eval decoded_payload = urldecode(_raw)
| where (match(decoded_payload, "GET\s+/[^\s]+\?id=") AND match
(decoded_payload, "(?i)(UNION\s+SELECT|OR\s+\d+=\d+|'\s+OR\s+'|--|#)"))
| eval Attack_Type="Confirmed SQLi Attempt", Severity="Critical"
| table _time, clientip, Attack_Type, Severity, decoded_payload
```

Alert type

ScheduledReal-time

Expires

24hour(s)

Trigger Conditions

Trigger alert when

Per-Result

Throttle

Trigger Actions

+ Add Actions

When triggered

Add to Triggered Alerts

SeverityCritical

Dashboard View

|                          |                                          |                                        |        |           |          |            |
|--------------------------|------------------------------------------|----------------------------------------|--------|-----------|----------|------------|
| <input type="checkbox"/> | 2026-02-21 23:17:59 Jordan Standard Time | SQL Injection Attack Patterns Detected | search | Real-time | Critical | Per Result |
|--------------------------|------------------------------------------|----------------------------------------|--------|-----------|----------|------------|

| _time               | clientip | Attack_Type            | Severity | decoded_payload                                                                                                                                                                            |
|---------------------|----------|------------------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2026-02-21 23:17:54 |          | Confirmed SQLi Attempt | Critical | 172.17.0.1 - - [21/Feb/2026:20:17:54 -0000] "GET /vulnerabilities/sql/7id/ OR '1'='1\$submit\$submit HTTP/1.1" 200 1854 "http://localhost/vulnerabilities/sql/7id/" UNION SELECT 1, user() |

Attacker Vision

DVWA

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

Vulnerability: SQL Injection

User ID:

Submit

ID: ' OR '1'='1

First name: admin

Surname: admin

ID: ' OR '1'='1

First name: Gordon

Surname: Brown

ID: ' OR '1'='1

First name: Hack

Surname: Me

ID: ' OR '1'='1

First name: Pablo

Surname: Picasso

ID: ' OR '1'='1

First name: Bob

Surname: Smith

## Phases and Actions

### 1. Preparation

- Ensure web server logs capture the full query string and request body.
- Pre-configure Web Application Firewall (WAF) to block common SQLi signatures.
- Implement parameterized queries (Prepared Statements) across all application database calls.

### 2. Detection & Analysis

- Review the decoded payload to determine the attacker's intent (e.g., data extraction vs. authentication bypass).
- Check web server response codes (e.g., 200 OK vs 500 Error) to see if the injection was successful.
- Identify the client IP and check for other malicious activity (e.g., directory brute forcing) from the same source.

### 3. Containment

- Immediately block the attacking IP address at the firewall or WAF level.
- Terminate any active web sessions associated with the attacking IP.
- If multiple critical injections are successful, temporarily place the affected page in maintenance mode.

### 4. Eradication

- Identify the vulnerable code parameter (e.g., ?id=) and implement proper input sanitization.
- Audit database logs for unauthorized SELECT, UPDATE, or DELETE operations executed during the attack window.
- If administrative data was targeted, initiate a password reset for all affected database users.

### 5. Recovery

- Re-run the attacking payload against the patched application to ensure the vulnerability is closed.
- Increase logging verbosity on the database server for the next 48 hours.
- Remove temporary IP blocks only after confirming the application is no longer vulnerable.

### 6. Lessons Learned & Reporting

- Document the specific coding flaw that allowed the injection.
- Provide training on secure coding practices (OWASP Top 10) to the development team.

### Success Metrics Table

| Metric                  | Target                    |
|-------------------------|---------------------------|
| Detection Time          | Real-time (Instantaneous) |
| Detection Accuracy      | High (urldecode used)     |
| Successful Exploitation | 0%                        |

### Analysis Questions and Answers

**1. Purpose of '1=1' in SQLi payload?**

*Answer: Creates TRUE condition to bypass authentication.*

**2. How to prevent SQLi?**

*Answer: Use parameterized queries or prepared statements.*

**3. Detection signs?**

*Answer: Unexpected data in response body or error messages.*



## Alert Settings & Dashboard

Edit Alert

Settings

Alert

File Inclusion & Directory Traversal Attempt

Description

This alert monitors for Local File Inclusion (LFI) and Directory Traversal attacks. It triggers when suspicious navigation patterns (e.g., ../, ../../) or requests for sensitive system

Search

```
index="main" source="/tmp/dvwa_logs/access.log"
| eval decoded_payload = urldecode(_raw)
| where (match(decoded_payload, "fi/?page=") AND match(decoded_payload, "(?i)(
  .\\.|\\.\\.\\.|etc/passwd|etc/shadow|boot\\.ini|win\\.ini)"))
| eval Attack_Type="LFI / Directory Traversal", Severity="High"
| table _time, clientip, Attack_Type, Severity, decoded_payload
```

Alert type

Scheduled

Real-time

Expires

24

hour(s) ▾

Trigger Conditions

Trigger alert when

Per-Result ▾

Throttle ?

☐

Trigger Actions

+ Add Actions ▾

When triggered

▾

Add to Triggered Alerts

Remove

Severity

High ▾

Cancel

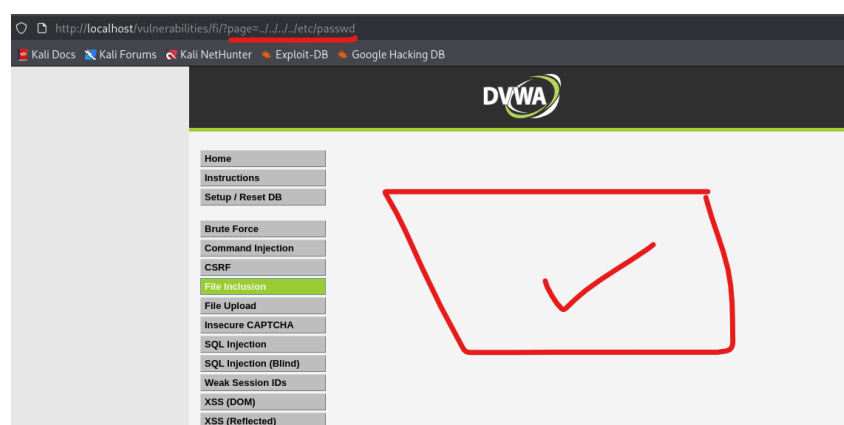
Save

## Dashboard View

| <input type="checkbox"/> | Time ▾                                   | Alert name ▴                                 | App ▴  | Type ▴    | Severity ▴ | Mode ▴     | Actions                                                                            |
|--------------------------|------------------------------------------|----------------------------------------------|--------|-----------|------------|------------|------------------------------------------------------------------------------------|
| <input type="checkbox"/> | 2026-02-21 23:38:09 Jordan Standard Time | File Inclusion & Directory Traversal Attempt | search | Real-time | ● High     | Per Result | <a href="#">View Results</a>   <a href="#">Edit Alert</a>   <a href="#">Delete</a> |
| <input type="checkbox"/> | 2026-02-21 23:37:34 Jordan Standard Time | File Inclusion & Directory Traversal Attempt | search | Real-time | ● High     | Per Result | <a href="#">View Results</a>   <a href="#">Edit Alert</a>   <a href="#">Delete</a> |

| _time               | clientip | Attack_Type     | Severity | decoded_payload                                                                                                                                                                   |
|---------------------|----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2026-02-21 23:38:03 |          | LFI / Directory | High     | 192.172.0.1 - - [21/Feb/2026:20:38:03 0000] "GET /vulnerabilities/lfi/pages/../../../../etc/passwd HTTP/1.1" 200 142 "-" Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 |

## Attacker Vision





## Phases and Actions

### 1. Preparation

- Ensure the Web Application Firewall blocks sequences like `../` and `..`.
- Follow the "Principle of Least Privilege"; ensure the web server user cannot read `/etc/passwd` or `/etc/shadow`.
- Disable `allow_url_include` and `allow_url_fopen` in PHP configurations if not required.

### 2. Detection & Analysis

- Review the `decoded_payload` to see how many directory levels the attacker attempted to jump.
- CRITICAL: Check the byte size and status code (200 OK) in logs to confirm if the file content was actually returned to the attacker.
- Identify if the tool used was a browser or an automated scanner (e.g., User-Agent strings).

### 3. Containment

- Immediately block the attacking IP address (e.g., 172.17.0.1) at the gateway.
- Invalidate all active sessions for the attacking user.

### 4. Eradication

- Replace dynamic file inclusion with a "Whitelist" of allowed files. Never pass user input directly into file-system APIs.
- Implement filters to strip all path traversal characters (`.`, `/`, `\`) from user input.

### 5. Recovery

- Use a web vulnerability scanner (OWASP ZAP/Burp Suite) to verify the fix.
- Set an alert for any 200 status codes appearing on the `vulnerabilities/fi/` path.

### 6. Lessons Learned & Reporting

- If `/etc/passwd` was successfully read, consider all local usernames as "Leaked".
- Check other pages for similar dynamic inclusion vulnerabilities.

## Success Metrics Table

| Metric                     | Target                            |
|----------------------------|-----------------------------------|
| MTTD (Mean Time to Detect) | <1 Minute                         |
| Evasion Visibility         | 100% (Decoded via urldecode)      |
| Successful Reads           | 0 (Blocked by server permissions) |

## Analysis Questions and Answers

**1. Which files are targeted in LFI?**

*Answer: /etc/passwd in Linux, or sensitive config files in web servers.*

**2. How to detect traversal attempts?**

*Answer: Monitor for '../' patterns in URL parameters.*

**3. Mitigation?**

*Answer: Input validation and web application firewall rules.*



## High-Frequency Directory Brute Force Detected (Web)

### Scenario

The SIEM has triggered a Medium severity alert for High-Frequency Directory Brute Force. A single source IP (172.17.0.1) generated over 9,000 failed attempts targeting the /vulnerabilities/ path. The logs show rapid-fire requests for non-existent pages like /zt, /zorum, and /zope, which is consistent with the use of an automated wordlist-based content discovery tool.

### Incident Classification

| Category         | Details                                              |
|------------------|------------------------------------------------------|
| Incident Type    | Reconnaissance / Brute Force                         |
| Severity         | Medium                                               |
| Priority         | Medium (Precursor to exploitation)                   |
| Detection Source | Apache/Nginx Access Logs (/tmp/dvwa_logs/access.log) |
| Timestamp        | 00:02:01                                             |
| Source IP        | 172.17.0.1                                           |
| Request Count    | 9,235 attempts                                       |
| Tool             | dirb (User-Agent: Mozilla/4.0 compatible; MSIE 6.0)  |
| MITRE ATT&CK     | T1046 (Network Service Scanning)                     |
| Tags             | Web, Directory Bruteforce, Reconnaissance            |
| Recommendation   | Block IP, implement rate limiting                    |

### Alert Rule & Logic

Monitors web access logs for client errors (Status Code  $\geq 400$ ). It calculates the total number of failed attempts and the count of unique pages requested per IP. The alert triggers when an IP exceeds 100 failed attempts.

```
index=main sourcetype="access-too_small" NOT "internal dummy connection"
| rex field=_raw "^(<src_ip>\d+\.\d+\.\d+\.\d+)\s-\s\s[[^\]]+\]\s\"(?<method>\w+)\s(?<uri>[^\s]+)\sHTTP/1\.\.\s\"(?<status_code>\d{3})\"
| where status_code >= 400
| stats count as failed_attempts, dc(uri) as unique_failed_pages by src_ip
| where failed_attempts > 100
```

Alert Settings & Dashboard

Edit Alert

Alert type

ScheduledReal-time

Run on Cron Schedule

Time Range

Last 60 minutes

Cron Expression

\*/1 \* \* \* \*

e.g. 00 18 \*\*\* (every day at 6PM). [Learn More](#)

Expires

24

hour(s)

Trigger Conditions

Trigger alert when

Number of Results

is greater than

0

Trigger

OnceFor each result

Throttle

☒

Suppress results containing field value

src\_ip

Suppress triggering for

60

second(s)

Trigger Actions

+ Add Actions

When triggered

Severity

Medium

Remove

Cancel

Save

Dashboard View

| <input type="checkbox"/> | Time                                     | Alert name                                    | App    | Type      | Severity |
|--------------------------|------------------------------------------|-----------------------------------------------|--------|-----------|----------|
| <input type="checkbox"/> | 2026-02-22 00:02:01 Jordan Standard Time | High-Frequency Directory Brute Force Detected | search | Scheduled | Medium   |

| i | Time                    | Event                                                                                                                                                                                                                                    |
|---|-------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| > | 2/22/26 12:13:12.000 AM | 172.17.0.1 - - [21/Feb/2026:21:13:12 +0000] "GET //vulnerabilities/zt HTTP/1.1" 404 453 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"<br>host = kali   source = /tmp/dvwa_logs/access.log   sourcetype = access-too_small     |
| > | 2/22/26 12:13:12.000 AM | 172.17.0.1 - - [21/Feb/2026:21:13:12 +0000] "GET //vulnerabilities/zorum HTTP/1.1" 404 456 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"<br>host = kali   source = /tmp/dvwa_logs/access.log   sourcetype = access-too_small  |
| > | 2/22/26 12:13:12.000 AM | 172.17.0.1 - - [21/Feb/2026:21:13:12 +0000] "GET //vulnerabilities/zope HTTP/1.1" 404 455 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"<br>host = kali   source = /tmp/dvwa_logs/access.log   sourcetype = access-too_small   |
| > | 2/22/26 12:13:12.000 AM | 172.17.0.1 - - [21/Feb/2026:21:13:12 +0000] "GET //vulnerabilities/zoom HTTP/1.1" 404 455 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"<br>host = kali   source = /tmp/dvwa_logs/access.log   sourcetype = access-too_small   |
| > | 2/22/26 12:13:12.000 AM | 172.17.0.1 - - [21/Feb/2026:21:13:12 +0000] "GET //vulnerabilities/zones HTTP/1.1" 404 456 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"<br>host = kali   source = /tmp/dvwa_logs/access.log   sourcetype = access-too_small  |
| > | 2/22/26 12:13:12.000 AM | 172.17.0.1 - - [21/Feb/2026:21:13:12 +0000] "GET //vulnerabilities/zone HTTP/1.1" 404 455 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"<br>host = kali   source = /tmp/dvwa_logs/access.log   sourcetype = access-too_small   |
| > | 2/22/26 12:13:12.000 AM | 172.17.0.1 - - [21/Feb/2026:21:13:12 +0000] "GET //vulnerabilities/zoeken HTTP/1.1" 404 457 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"<br>host = kali   source = /tmp/dvwa_logs/access.log   sourcetype = access-too_small |

Attacker Vision

```
(kali@kali)-[~]  
$ dirb http://172.17.0.1//vulnerabilities/
```

## Phases and Actions

### 1. Preparation

- Implement `mod_evasive` (Apache) or `limit_req` (Nginx) to automatically throttle high-frequency requesters.
- Create "Directory Honeytokens" (e.g., `/admin_backup/`) that trigger an immediate high-priority alert if accessed.
- Ensure the WAF identifies and blocks known scanner User-Agents.

### 2. Detection & Analysis

- Confirm the scale of the attack. In this instance, the attacker made 9,235 attempts.
- Search logs for the same `src_ip` but with a 200 OK status code to see if the scanner discovered sensitive pages.
- Use whois or Threat Intel feeds to determine if the `src_ip` is a known malicious actor or a Tor exit node.

### 3. Containment

- Use Fail2Ban to automatically block the IP at the iptables level for 24 hours.
- Add the source IP to the WAF blocklist specifically for the `/vulnerabilities/` URI prefix.

### 4. Eradication

- Ensure sensitive files (e.g., `.env`, `.git`, `config.php.bak`) are not accessible via the web root.
- Ensure `robots.txt` does not inadvertently list sensitive directories that an attacker could then target.

### 5. Recovery

- Watch for the attacker returning from a different IP address or using a "low and slow" scanning technique.
- Implement IP whitelisting for administrative subdirectories.

### 6. Lessons Learned & Reporting

- Evaluate if the scanner discovered any pages that were previously unknown to the security team.
- Update the SIEM threshold if 100 attempts is causing too many false positives from legitimate crawlers.

## Success Metrics Table

| Metric              | Target                               |
|---------------------|--------------------------------------|
| Detection Speed     | <1 Minute (SIEM Cron cycle)          |
| False Positive Rate | <5% (Targeting only 400+ errors)     |
| Blocked Scanner IPs | 100% of confirmed brute-force actors |

## Analysis Questions and Answers

1. **What is directory brute force?**

*Answer: Repeated attempts to enumerate directories or files on a web server.*

2. **Detection?**

*Answer: High number of 404 responses from a single IP.*

3. **Mitigation?**

*Answer: Rate-limit requests and block offending IPs.*

## Unauthorized XSS Payload Injection Detected (Web)

### Scenario

The SIEM has triggered a Critical severity alert detecting a potential Cross-Site Scripting (XSS) attack. An attacker is attempting to inject malicious JavaScript payloads (such as `<script>`, `onerror`, or `document.cookie`) into HTTP GET request parameters. This activity typically aims to steal session cookies, redirect users to malicious sites, or deface the web application.

### Incident Classification

| Category         | Details                                     |
|------------------|---------------------------------------------|
| Incident Type    | Injection / Cross-Site Scripting (XSS)      |
| Severity         | CRITICAL                                    |
| Priority         | High                                        |
| Detection Source | Web Access Logs (/tmp/dvwa_logs/access.log) |
| Timestamp        | 23:02:28                                    |
| Source IP        | 172.17.0.1                                  |
| MITRE ATT&CK     | T1059 (Command and Scripting Interpreter)   |
| Tags             | XSS, Injection, DVWA, Critical              |
| Recommendation   | Block IP, implement output encoding, CSP    |

### Alert Rule & Logic

Monitors web access logs for common JavaScript execution patterns within URL parameters. It uses `urldecode` to identify payloads that may be hidden via URL encoding.

```
index="main" source="/tmp/dvwa_logs/access.log"
| eval decoded_url = urldecode(_raw)
| where (match(decoded_url, "\\?\\w+=") AND match(decoded_url, "(?i)(<script|alert\\(|onerror=|onload=|eval\\(|src=x|document\\.cookie)"))
| eval Attack_Type="Generic XSS Detection", Severity="Critical"
| table _time, clientip, Attack_Type, Severity, decoded_url
```

## Alert Settings & Dashboard

### Edit Alert

Settings

Alert

Unauthorized XSS Payload Injection Detecte

Description

"This alert triggers when an incoming HTTP GET request contains suspicious JavaScript patterns (e.g., <script>, onerror, document.cookie) within URL parameters.

Search

index="main" source="/tmp/dvwa\_logs/access.log"  
| eval decoded\_url = urldecode(\_raw)  
| where (match(decoded\_url, "\?w+=") AND match(decoded\_url, "(?i)(<script|aler  
(|onerror=|onload=|eval\(|src=x|document\.cookie)"))  
| eval Attack\_Type="Generic XSS Detection", Severity="Critical"  
| table \_time, clientip, Attack\_Type, Severity, decoded\_url

Alert type

Scheduled

Real-time

Expires

24

hour(s)

Trigger Conditions

Trigger alert when

Per-Result

Throttle

☐

Trigger Actions

+ Add Actions

When triggered

Severity

Critical

Cancel

Save

## Dashboard View

| <input type="checkbox"/> | Time                                     | Alert name                                 | App    | Type      | Severity | Mode       | Actions                                                                            |
|--------------------------|------------------------------------------|--------------------------------------------|--------|-----------|----------|------------|------------------------------------------------------------------------------------|
| <input type="checkbox"/> | 2026-02-21 23:02:28 Jordan Standard Time | Unauthorized XSS Payload Injection Detecte | search | Real-time | Critical | Per Result | <a href="#">View Results</a>   <a href="#">Edit Alert</a>   <a href="#">Delete</a> |

| _time               | clientip | Attack_Type           | Severity | decoded_url                                                                                                                                                                                                                                                    |
|---------------------|----------|-----------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2026-02-21 23:02:28 |          | Generic XSS Detection | Critical | 172.17.0.1 - - [21/Feb/2026:20:02:29 -0800] "GET /vulnerabilities/xss_r/?name=<img src=x onerror=alert('XSS_via_Image')> HTTP/1.1" 200 1786 "http://localhost/vulnerabilities/xss_r/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0" |

## Attacker Vision

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

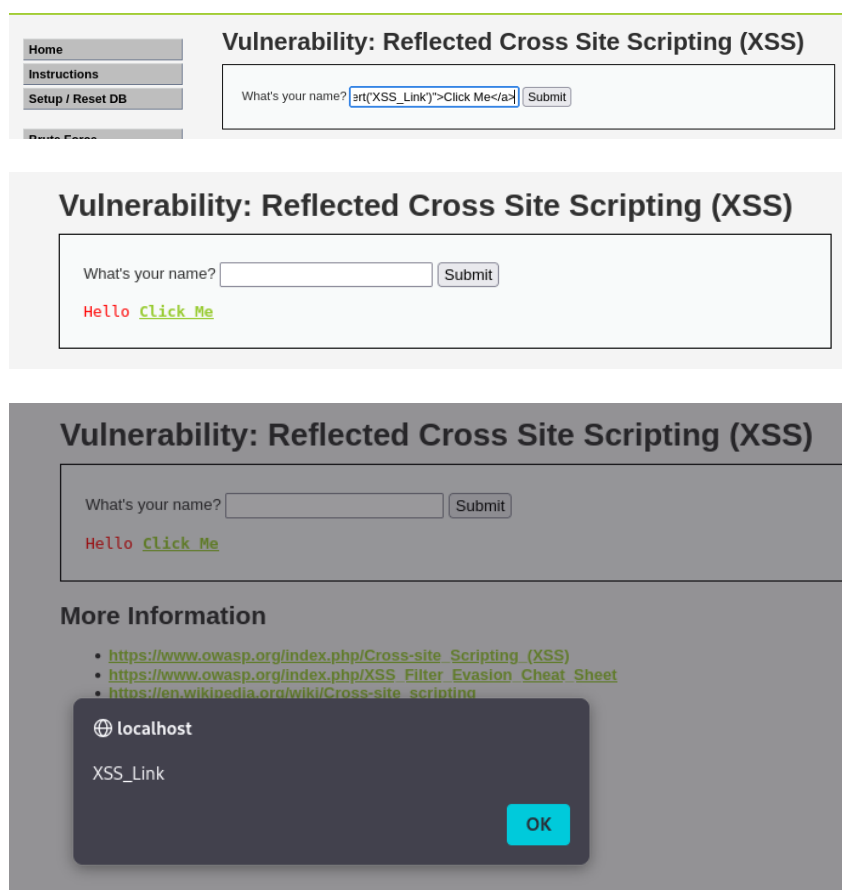


### Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

#### More Information

- [https://www.owasp.org/index.php/Cross-site\\_Scripting\\_\(XSS\)](https://www.owasp.org/index.php/Cross-site_Scripting_(XSS))
- [https://www.owasp.org/index.php/XSS\\_Filter\\_Evasion\\_Cheat\\_Sheet](https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet)
- [https://en.wikipedia.org/wiki/Cross-site\\_scripting](https://en.wikipedia.org/wiki/Cross-site_scripting)
- <http://www.cgisecurity.com/xss-faq.html>
- <http://www.scriptalert1.com/>



## Phases and Actions

### 1. Preparation

- Ensure the Web Application Firewall is configured with signatures for common XSS patterns.
- Implement a strict Content Security Policy (CSP) to restrict where scripts can be loaded from and prevent the execution of inline scripts.
- Train developers on output encoding and input validation to prevent reflected and stored XSS.

### 2. Detection & Analysis

- Examine the decoded\_url to determine if the attack is a simple "Proof of Concept" (like alert(1)) or a malicious attempt to steal document.cookie.
- Based on the URI, identify if this is Reflected XSS (in the URL) or potentially Stored XSS if the input is saved to a database.
- Check the client IP to see if the attack is broad or targeting specific administrative pages.

### 3. Containment

- Immediately block the source IP (e.g., 172.17.0.1) at the WAF or Firewall level.
- If the payload targeted document.cookie, consider invalidating all active user sessions to prevent session hijacking.

#### 4. Eradication

- Implement context-aware output encoding on the vulnerable page (e.g., `/vulnerabilities/xss_r/`).
- Sanitize all user-supplied input to remove or neutralize HTML tags and JavaScript event handlers.

#### 5. Recovery

- Perform a focused scan on the application to ensure no other parameters are vulnerable to similar injections.
- Continue monitoring for the blocked IP or similar patterns from new sources for the next 72 hours.

#### 6. Lessons Learned & Reporting

- Identify why existing filters failed to catch the onerror event handler.
- Document the attack timeline and the effectiveness of the real-time alert.

#### Success Metrics Table

| Metric             | Target                                             |
|--------------------|----------------------------------------------------|
| Detection Time     | Real-time (Instantaneous)                          |
| Detection Accuracy | High (utilizing urldecode for obfuscated payloads) |

#### Analysis Questions and Answers

**1. What is XSS injection?**

*Answer: Injecting malicious scripts to execute in users' browsers.*

**2. Detection?**

*Answer: Monitor unexpected script tags or payloads in requests.*

**3. Mitigation?**

*Answer: Input validation, Content Security Policy (CSP), and escaping output.*



## High-Velocity DoS Attack Detected via Header Signature (Web)

### Scenario

The SIEM has triggered a High severity alert for a Denial of Service (DoS) attack. A single source IP (172.17.0.1) is flooding the web server with a high volume of requests, exceeding the threshold of 10 requests per second within a 1-minute window. This activity aims to exhaust server resources (CPU, RAM, or bandwidth), leading to service degradation or a complete outage for legitimate users.

### Incident Classification

| Category         | Details                                                     |
|------------------|-------------------------------------------------------------|
| Incident Type    | Availability / Denial of Service (DoS)                      |
| Severity         | High                                                        |
| Priority         | High (Potential for Service Outage)                         |
| Detection Source | Web Access Logs (/tmp/dvwa_logs/access.log)                 |
| Timestamp        | 00:03:01                                                    |
| Threshold        | >10 requests/sec                                            |
| Source IP        | 172.17.0.1                                                  |
| MITRE ATT&CK     | T1498 (Network Denial of Service)                           |
| Tags             | Web, DoS, DDoS, Availability                                |
| Recommendation   | Block IP, enable rate limiting, use DDoS protection service |

### Alert Rule & Logic

Calculates the request rate per second for each source IP. It triggers when an IP exceeds the defined threshold of 10 requests per second, suggesting automated stress-testing or a malicious flood.

```
index=main sourcetype="access-too_small"
| rex field=_raw "^(?<client_ip>\d+\.\d+\.\d+\.\d+)"
| stats count as requests_per_second by _time, client_ip
| where requests_per_second > 10
```

## Alert Settings & Dashboard

## Dashboard View

| <input type="checkbox"/> Time ▾                                   | Alert name ▾                                           | App ▾  | Type ▾    | Severity ▾ |
|-------------------------------------------------------------------|--------------------------------------------------------|--------|-----------|------------|
| <input type="checkbox"/> 2026-02-22 00:07:00 Jordan Standard Time | High-Velocity DoS Attack Detected via Header Signature | search | Scheduled | High       |

| _time ▾             | client_ip ▾ | requests_per_second ▾ |
|---------------------|-------------|-----------------------|
| 2026-02-22 00:13:11 | 172.17.0.1  | 4387                  |
| 2026-02-22 00:13:12 | 172.17.0.1  | 239                   |

## Attacker Vision

```
(kali@kali)-[~]
$ ab -n 10000 -c 100 http://172.17.0.1/vulnerabilities/
This is ApacheBench, Version 2.3 <$Revision: 1923142 $>
Copyright 1996 Adam Twiss, Zeus Technology Ltd, http://www.zeustech.net/
Licensed to The Apache Software Foundation, http://www.apache.org/
```

### 1. Preparation

- Implement a Load Balancer to distribute traffic across multiple web server instances.
- Configure iptables (hashlimit) or Nginx limit\_req\_zone to drop traffic that exceeds legitimate thresholds.
- Deploy a cloud-based DDoS mitigation service (e.g., Cloudflare, AWS Shield) for edge protection.

## 2. Detection & Analysis

- Check the server's CPU and Memory usage via `top` or `http` to determine if the DoS is impacting system stability.
- Look for specific header signatures (e.g., custom User-Agents or abnormal Referer fields) that can be used for precise blocking.
- Determine if the attack is targeting a specific resource-intensive page (like a login or search form) or the root directory.

## 3. Containment

- Manually block the offending IP address at the edge firewall or via `iptables -A INPUT -s 172.17.0.1 -j DROP`.
- Activate "I'm Under Attack" mode on the WAF to enforce JavaScript challenges on all incoming visitors.

## 4. Eradication

- Apply filters to drop packets matching the identified attack signature.
- Clear established TCP connections from the attacking IP to free up server sockets.

## 5. Recovery

- Monitor the `req_per_sec` metric to ensure traffic has returned to baseline levels.
- Restart web services (Apache/Nginx) if they became unresponsive during the flood.

## 6. Lessons Learned & Reporting

- Evaluate if the "10 req/sec" threshold is too low for normal peak usage.
- Document the total downtime (if any) and the effectiveness of the containment measures.

### Success Metrics Table

| Metric               | Target                      |
|----------------------|-----------------------------|
| Detection Speed      | <1 Minute (Scheduled cycle) |
| Mitigation Time      | <10 Minutes                 |
| Uptime during Attack | >99.9%                      |

### Analysis Questions and Answers

#### 1. How does this DoS attack work?

*Answer: Flooding HTTP requests using specific headers to overload the server.*

#### 2. Detection?

*Answer: Monitor high request rate and abnormal headers in logs.*

#### 3. Mitigation?

*Answer: Rate limiting, WAF rules, or CDN "I'm under attack" mode.*